

Elektronische Gesundheitskarte und Telematikinfrastruktur

Spezifikation Basis-Consumer

Version: 1.12.1
Revision: 1518443
Stand: 18.02.2026
Status: freigegeben
Klassifizierung: öffentlich
Referenzierung: gemSpec_Basis_Consumer

Dokumentinformationen

Änderungen zur Vorversion

Anpassungen des vorliegenden Dokumentes im Vergleich zur Vorversion können Sie der nachfolgenden Tabelle entnehmen.

Dokumentenhistorie

Version	Stand	Kap./ Seite	Grund der Änderung, besondere Hinweise	Bearbeitung
1.0.0	15.05.2019		initiale Erstellung des Dokuments	gematik
1.1.0	28.06.2019		Einarbeitung P19.1	gematik
1.2.0	30.06.2020		Einarbeitung P22.1	gematik
1.3.0	10.09.2020		Einarbeitung P22.3	gematik
1.3.1	19.02.2021		Clientmodul KOM-LE ist für den KTR-Consumer nicht verpflichtend	gematik
1.3.2	06.08.2021		Einarbeitung Consumer_Maintenance_21.3	gematik
1.4.0	17.02.2022		Einarbeitung Consumer_Maintenance_21.4 und CI_Maintenance_21.2	gematik
1.5.0	13.05.2022	6.5.1	Einarbeitung Consumer_Maintenance_22.1	gematik
1.6.0	18.09.2023		Einarbeitung Consumer_Maintenance_23.1	gematik
1.7.0	30.01.2024		Anpassung für ePA für alle, Einarbeitung Consumer_Maintenance_23.2	gematik
1.8.0	12.08.2024		Einarbeitung Consumer_24.1	gematik
1.9.0	14.08.2024		Einarbeitung Consumer_24.2	gematik

1.10.0	20.11.2024		Einarbeitung Consumer_24.3	gematik
1.10.1	27.11.2024	6.2.2.2	SignPlain-Operation zum Einstellen einer Befugnis ergänzt	gematik
1.10.2	02.12.2024	6.2.2.2	SignPlain-Operation zum Einstellen einer Befugnis angepasst	gematik
1.11.0	05.03.2025		Ausbau KTR-Consumer	gematik
1.11.1	20.10.2025		Entfernung A_17327	gematik
1.12.0	25.11.2025		CVDP-Meldung (Anpassung ergänzend zu KIM 1.5.2-10)	gematik
1.12.1	18.02.2026		Entfernung A_17503-01 (Afo-Inhalt doppelt)	gematik

Inhaltsverzeichnis

1 Einordnung des Dokumentes.....	6
1.1 Zielsetzung.....	6
1.2 Zielgruppe.....	6
1.3 Geltungsbereich.....	6
1.4 Abgrenzungen.....	6
1.5 Methodik.....	7
2 Systemüberblick.....	8
3 Systemkontext.....	9
4 Zerlegung der Produkttypen.....	10
4.1 Basisfunktionen.....	10
4.2 LDAP-Proxy.....	10
4.3 Clientmodul KOM-LE.....	10
5 Übergreifende Festlegungen.....	12
5.1 Anschluss an die TI.....	12
5.1.1 Anbindung per LAN/WAN.....	12
5.1.1.1 Funktionsmerkmalweite Aspekte.....	12
5.1.1.1.1 Netzwerksegmentierung.....	13
5.1.1.2 Durch Ereignisse ausgelöste Reaktionen.....	14
5.1.2 Zeitdienst.....	15
5.1.3 Namensdienst und Dienstlokalisierung.....	15
5.1.3.1 Funktionsmerkmalweite Aspekte.....	15
5.1.3.2 Interne TUCs, auch durch Fachmodule nutzbar.....	16
5.1.3.2.1 TUC_CON_362 „Liste der Dienste abrufen“.....	16
5.1.3.3 Operationen an der Clientsystemschnittstelle.....	17
5.1.3.4 Betriebsaspekte.....	17
5.2 Sicherheit.....	18
5.3 Identitäten.....	19
5.4 Schnittstellen.....	21
6 Funktionsmerkmale.....	22
6.1 Verschlüsselungsdienst.....	22
6.1.1 Durch Module nutzbare TUCs.....	22
6.1.2 Operationen an der Clientsystemschnittstelle.....	22
6.1.2.1 EncryptDocument.....	22
6.1.2.2 DecryptDocument.....	25
6.2 Signaturdienst.....	27
6.2.1 Durch Module nutzbare TUCs.....	27

6.2.2 Operationen an der Clientsystemschnittstelle.....	28
6.2.2.1 <i>SignDocument</i>	28
6.2.2.2 <i>SignPlain</i>	32
6.2.2.3 <i>VerifyDocument</i>	34
6.2.2.4 <i>ExternalAuthenticate</i>	38
6.3 Zertifikatsdienst.....	41
6.3.1 Durch Module nutzbare TUCs.....	41
6.3.2 Operationen an der Clientsystemschnittstelle.....	41
6.3.2.1 <i>ReadCertificate</i>	42
6.3.2.2 <i>VerifyCertificate</i>	46
6.4 LDAP-Proxy.....	49
6.4.1 Durch Module nutzbare TUCs.....	49
6.4.2 Unterstützte LDAPv3-Operationen an der Clientsystemschnittstelle.....	49
6.5 Clientmodul KOM-LE.....	50
6.5.1 Allgemeine Anforderungen.....	50
6.5.1.1 <i>Eingeschaltete ECC-preferred-Funktionalität</i>	51
6.5.1.2 <i>Ausgeschaltete ECC-preferred-Funktionalität</i>	52
6.5.2 Senden von Nachrichten.....	62
6.5.3 Empfangen von Nachrichten.....	64
6.6 Realisierung der Leistungen der TI-Plattform.....	65
6.6.1 Schnittstelle für Kartenkommandos.....	65
6.6.2 Schnittstelle für PIN-Operationen und Anbindung der Karten der TI.....	66
7 Anhang A - Verzeichnisse.....	68
7.1 Abkürzungen.....	68
7.2 Glossar.....	69
7.3 Abbildungsverzeichnis.....	69
7.4 Tabellenverzeichnis.....	69
7.5 Referenzierte Dokumente.....	70
7.5.1 Dokumente der gematik.....	70
7.5.2 Weitere Dokumente.....	71
8 Anhang B - Übersicht über die verwendeten Versionen.....	73
9 Anhang C - Übersicht der genutzten Systemprozesse.....	74

1 Einordnung des Dokumentes

1.1 Zielsetzung

Die vorliegende Spezifikation definiert die Anforderungen an Herstellung, Test und Betrieb des Produkttyps Basis-Consumer.

Der Basis-Consumer ist ein Produkttyp der TI-Plattform, der in der Rolle eines Consumers mit der Telematikinfrastruktur (TI) interagiert und dabei sowohl Anteile der TI-Plattform als auch Anteile des sicheren Übermittlungsverfahrens KOM-LE enthält.

1.2 Zielgruppe

Das Dokument ist maßgeblich für Anbieter und Hersteller des Produkttyps Basis-Consumer sowie für Anbieter und Hersteller von Produkten, die die Schnittstellen des Produkttyps Basis-Consumer nutzen.

1.3 Geltungsbereich

Dieses Dokument enthält normative Festlegungen zur Telematikinfrastruktur des deutschen Gesundheitswesens. Der Gültigkeitszeitraum der vorliegenden Version und deren Anwendung in Zulassungs- oder Abnahmeverfahren wird durch die gematik GmbH in gesonderten Dokumenten (z.B. gemPTV_ATV_Festlegungen, Produkttypsteckbrief, Leistungsbeschreibung) festgelegt und bekannt gegeben.

Schutzrechts-/Patentrechtshinweis

Die nachfolgende Spezifikation ist von der gematik allein unter technischen Gesichtspunkten erstellt worden. Im Einzelfall kann nicht ausgeschlossen werden, dass die Implementierung der Spezifikation in technische Schutzrechte Dritter eingreift. Es ist allein Sache des Anbieters oder Herstellers, durch geeignete Maßnahmen dafür Sorge zu tragen, dass von ihm aufgrund der Spezifikation angebotene Produkte und/oder Leistungen nicht gegen Schutzrechte Dritter verstoßen und sich ggf. die erforderlichen Erlaubnisse/Lizenzen von den betroffenen Schutzrechtsinhabern einzuholen. Die gematik GmbH übernimmt insofern keinerlei Gewährleistungen.

1.4 Abgrenzungen

Spezifiziert werden in dem Dokument die von dem Produkttyp Basis-Consumer bereitgestellten (angebotenen) Schnittstellen. Benutzte Schnittstellen werden hingegen in der Spezifikation desjenigen Produkttypen beschrieben, der diese Schnittstelle bereitstellt. Auf die entsprechenden Dokumente wird referenziert (siehe auch Anhang A5).

Die vollständige Anforderungslage für die Produkttypen ergibt sich aus weiteren Konzept- und Spezifikationsdokumenten, diese sind in den Produkttypsteckbriefen des Produkttyps Basis-Consumer verzeichnet.

1.5 Methodik

Anforderungen als Ausdruck normativer Festlegungen werden durch eine eindeutige ID sowie die dem RFC 2119 [RFC2119] entsprechenden, in Großbuchstaben geschriebenen deutschen Schlüsselworte MUSS, DARF NICHT, SOLL, SOLL NICHT, KANN gekennzeichnet.

Sie werden im Dokument wie folgt dargestellt:

<AFO-ID> - <Titel der Afo>

Text / Beschreibung

[<=]

Dabei umfasst die Anforderung sämtliche zwischen der ID und der Textmarke angeführten Inhalte.

2 Systemüberblick

Der Produkttyp Basis-Consumer ist eine Realisierung des konzeptionellen Konstrukts „RZ-Consumer“ aus [gemKPT_Arch_TIP]. D.h., er agiert als Consumer in der Telematikinfrastruktur (TI), nutzt dabei zentrale Dienste, die Dienste des sicheren Übermittlungsverfahrens und ggf. fachanwendungsspezifische Dienste und wird in einem Rechenzentrum entsprechend den Vorgaben der TI betrieben. Der Produkttyp bieten für externe Clients eine Menge von Basisfunktionen (z.B. kryptographische Operationen), ermöglichen den Zugriff auf weitere Anwendungen des Gesundheitswesens und die Nutzung des sicheren Übermittlungsverfahrens KOM-LE.

Der Basis-Consumer ermöglicht es den berechtigten Organisationen des Gesundheitswesens an der KIM-Kommunikation in der TI teilzunehmen. Der Zugriff auf Fachanwendungen der TI ist dieser Nutzergruppe nicht gestattet. Der Produkttyp enthält demnach zwar keine Fachmodule, aber ein Clientmodul KOM-LE zur Nutzung des sicheren Übermittlungsverfahrens. Auf technischer Ebene wird die jeweilige Nutzergruppe durch die kryptographische Identität der SMC-B Org oder SMC-B KTR (jeweils auf Basis oid_kostenträger) identifiziert, die in einem HSM oder auf einer Karte gespeichert wird.

3 Systemkontext

Nachfolgend wird angelehnt an den Systemüberblick aus [gemKPT_Arch_TIP] die Einbettung des Produkttyps Basis-Consumer in das System der TI dargestellt. Die Darstellung ist reduziert auf die Produkttypen der TI sowie Clients und Anwendungen außerhalb der TI, mit denen potentiell eine Interaktion stattfindet. Die Festlegungen des vorliegenden Dokuments beziehen sich auf den Produkttyp Basis-Consumer als Ganzes und das logische Konstrukt des Consumer-Adapters aus [gemKPT_Arch_TIP], das den Umfang der Basisfunktionen des Produkttyps festlegt.

Unter "SM-B Basis-Consumer" wird in der Abbildung 1 eine Identität verstanden, die Zertifikate gemäß [gemSpec_PKI] enthält.

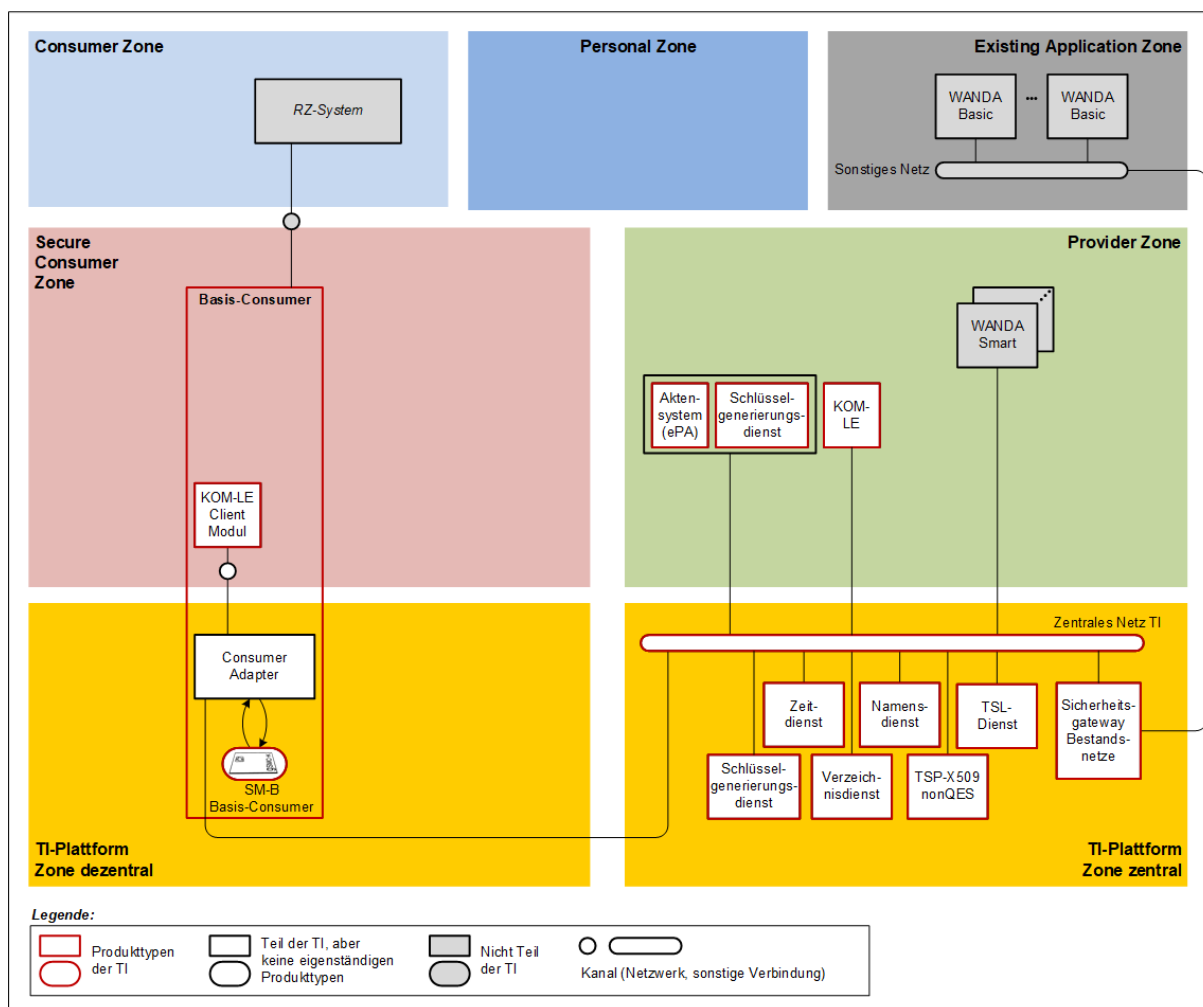


Abbildung 1: Systemkontext für Basis-Consumer

4 Zerlegung der Produkttypen

Der Produkttyp Basis-Consumer teilt sich in die folgenden Bestandteile auf:

- Basisfunktionen,
- LDAP-Proxy und
- Clientmodul KOM-LE

Die Festlegungen des vorliegenden Dokuments beziehen sich auf den Produkttyp Basis-Consumer als Ganzes sowie dessen oben aufgeführten Bestandteile, mit Ausnahme des Clientmoduls KOM-LE, welches in [gemSpec_CM_KOMLE], beschrieben ist. Das logische Konstrukt des Consumer-Adapters aus [gemKPT_Arch_TIP], wird durch die Basisfunktionen und den LDAP-Proxy in dem für die Produkttypen benötigten Umfang umgesetzt.

4.1 Basisfunktionen

Die Basisfunktionen enthalten:

- den Verschlüsselungsdienst zum Ver- und Entschlüsseln von Dokumenten
- den Signaturdienst zum Signieren und Signaturprüfen
- den Zertifikatsdienst, um Zertifikate zu überprüfen
- netztechnische Anbindung an die Telematikinfrastuktur (Interface, Firewall und DNS)

4.2 LDAP-Proxy

Der Basis-Consumer ermöglicht es Clientsystemen und Clientmodulen durch Nutzung des LDAP-Proxies Daten aus dem Verzeichnisdienst der TI-Plattform (VZD) abzufragen. Die Kommunikation erfolgt über das LDAPv3-Protokoll.

4.3 Clientmodul KOM-LE

Der Basis-Consumer enthält ein Clientmodul KOM-LE, um das sichere Übermittlungsverfahren KOM-LE nutzen zu können. Es werden die Anwendungsfälle „Senden und Empfangen von Nachrichten“ unterstützt. Die Spezifikation [gemSpec_CM_KOMLE] gilt in großen Teilen auch für den Basis-Consumer. Es gibt aber verschiedene Bereiche, in denen eine Anpassung für den Basis-Consumer erforderlich ist. Für diese Bereiche werden neue Anforderungen aufgenommen, die statt der bestehenden Anforderungen aus [gemSpec_CM_KOMLE] zu verwenden sind. Die Bereiche sind:

- Nutzung des Basis-Consumers
Die Spezifikation des Clientmoduls [gemSpec_CM_KOMLE] schreibt an einigen Stellen die Nutzung des Konnektors für Signatur/Signaturprüfung und Ver-/Entschlüsselung vor. Diese Anforderungen werden ersetzt durch Anforderungen, die die Nutzung der Systemprozesse im Basis-Consumer vorschreiben.

- Clientsystemschnittstelle des Moduls
Die SMTP/POP3-Schnittstelle des Clientmoduls soll beibehalten werden. Abweichend von [gemSpec_CM_KOMLE] werden die Informationen bzgl. der Adresse und des Ports des Mail Transfer Agents (MTA, KOM-LE Fachdienst) und die Informationen des Aufrufkontext nicht beim Aufruf mitgegeben, sondern im Basis-Consumer lokal konfiguriert.

5 Übergreifende Festlegungen

5.1 Anschluss an die TI

5.1.1 Anbindung per LAN/WAN

Unter Anbindung per LAN/WAN werden die Mechanismen beschrieben, mit denen der Basis-Consumer auf der einen Seite in das lokale Netz der Einsatzumgebung und auf der anderen Seite in die zentrale TI sowie WANDA Basic und die WANDA Smart angebunden wird. Diese wesentlichen Aspekte betreffen Routing und Firewall.

5.1.1.1 Funktionsmerkmalweite Aspekte

A_17396 -Verhalten als IPv4-Router

Der Basis-Consumer MUSS sich nach den in [RFC1812#1.1.3] definierten Rahmenbedingungen als IP-Version-4-(IPv4)-Router verhalten. Die in [RFC2644] geforderten Aktualisierungen zum [RFC1812] MÜSSEN umgesetzt werden.[<=]

A_17397-01 -IP-Pakete mit Source Route Option

Der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS durchsetzen, dass keine IP-Pakete mit gesetzter Source Route Option gemäß [RFC791] erzeugt oder weitergeleitet werden. In beiden Sicherheitsnachweisen muss klar dargestellt werden, wo die Sicherheitsleistung umgesetzt ist.[<=]

A_17400-02 -NAT-Umsetzung

Der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS für die Kommunikation mit Adressbereichen der TI sowie WANDA Basic und WANDA Smart eine Network Address Translation (NAT) gemäß [RFC3022#2.2, 3, 4.1-4.3] vornehmen. Für die Umsetzung der Private Local Address aus den Adressbereichen der Einsatzumgebung MUSS die verwendete IP-Adresse aus dem vom Anbieter Zentrale Plattform Dienste (AZPD) bereitgestellten Adress-Pool entnommen werden und als Global Address genutzt werden.[<=]

A_17405-01 -Nur IPv4. IPv6 nur hardwareseitig vorbereitet

Der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS die IP-Version 4 (IPv4) für alle seine IP-Schnittstellen unterstützen. Die eingesetzte Hardware MUSS für den Einsatz von IPv4 und IPv6 im Dual-Stack-Mode geeignet sein. Bis zu einer Migration von IPv4 auf IPv6 MUSS der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung sämtliche empfangenen IP-Pakete der Version 6 (IPv6) verwerfen. In beiden Sicherheitsnachweisen muss klar dargestellt werden, wo die Sicherheitsleistung umgesetzt ist.[<=]

Die Anbindung des Basis-Consumers an die zentrale TI erfolgt über einen Sicheren Zentralen Zugangspunkt (SZZP), siehe [gemSpec_Net#3.1.1]. Dieser Produkttyp unterstützt kein dynamisches Routing.

A_17406-01 -Kein dynamisches Routing

Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS durchsetzen, dass nicht dynamische Routing-Protokolle eingesetzt werden. In beiden Sicherheitsnachweisen muss klar dargestellt werden, wo die Sicherheitsleistung umgesetzt ist.[<=]

5.1.1.1.1 Netzwerksegmentierung

In Anlehnung an die in der [gemSpec_Net#2.3.3] definierten Netzwerksegmente werden in der Basis-Consumerspezifikation die folgenden Bezeichner verwendet:

Tabelle 1: Mapping der Netzwerksegmente

ReferenzID im Basis-Consumer	Adressbereich für die TI-Produktivumgebung	Adressbereich für die TI-Testumgebung	Adressbereich für die TI-Referenzumgebung
NET_TI_ZENTRAL	TI_Zentral - Zentrale Dienste	TI_Test_Zentral - Zentrale Dienste	Ist durch den Testbetriebsverantwortlichen zu definieren.
NET_TI_GESICHERTE_FD	TI_Fachdienste - Gesicherte Fachdienste	TI_Test_Fachdienste - Gesicherte Fachdienste	Ist durch den Testbetriebsverantwortlichen zu definieren.
NET_TI_OFFENE_FD	TI_Fachdienste - Offene Fachdienste	TI_Test_Fachdienste - Offene Fachdienste	Ist durch den Testbetriebsverantwortlichen zu definieren.
NET_WANDA_Smart	WANDA Smart	WANDA Smart	WANDA Smart
NET_CONSUMER	Liste der Netzwerke die in der Einsatzumgebung über den Basis-Consumer erreichbar sind. Ein Eintrag der Liste enthält die Netzwerkadresse und den Netzwerkpräfix.		
NET_WANDA_Basic	WANDA Basic	WANDA Basic	WANDA Basic

A_17411-01 -Kommunikation mit NET_TI_Offene_FD

Der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS sicherstellen, dass IP-Pakete mit dem Ziel NET_TI_Offene_FD und NET_WANDA_Smart weitergeleitet werden.【<=】

A_17415-01 -Kommunikation mit NET_TI_ZENTRAL

Der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS sicherstellen, dass IP-Pakete in Richtung NET_TI_ZENTRAL ausschließlich vom Basis-Consumer ausgehen. In beiden Sicherheitsnachweisen muss klar dargestellt werden, wo die Sicherheitsleistung umgesetzt ist.【<=】

A_21998-01 -Kommunikation mit NET_WANDA_Basic

Der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS sicherstellen, dass IP-Pakete mit dem Ziel NET_WANDA_Basic weitergeleitet werden.【<=】

A_17417-01 -Einschränkung von nicht genehmigten Traffic

Der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS nicht genehmigten Traffic blockieren und dabei folgendes umsetzen:

- "default deny"
- Einschränkung auf IP-Protokolle 1 (ICMP; eingeschränkt auf Typ 8 und Typ 0 und ausschließlich für, per Anforderung genehmigten, Traffic), 17 (UDP) und 6 (TCP)
- Einschränkung auf genau nur die Ports die für den Betrieb unerlässlich sind
- abgelehnten IP-Pakete verwerfen (DROP), ohne ein ICMP-Destination-Unreachable (Type 3) zu schicken
- Maßnahmen zur Erkennung und Behebung unberechtigter oder verdächtiger Netzwerkaktivitäten (bspw. über Korrelation und Auswertung von Log-Daten).

In beiden Sicherheitsnachweisen muss klar dargestellt werden, wo die Sicherheitsleistung umgesetzt ist.

[<=]

Umsetzungshinweis für den Hersteller: Es können zwei getrennten Firewall-Regelsets für den LAN- bzw. für den WAN-Adapter verwendet werden.

A_17424-01 -Firewall-Protokollierung

Der Basis-Consumer als Produkt oder dessen Anbieter über die Betriebsumgebung MUSS an der Firewall folgende Aktivitäten nachvollziehbar protokollieren:

- Konfigurationsänderungen der Firewall
- Zeitstempel, Aktion (Add/Delete/Change), Details (Beschreibung der Änderung), Auslöser (Prozess/User)
- von der Firewall verworfene IP-Pakete, wobei Layer 3 Broadcasts von der Protokollierung ausgenommen werden können.

In beiden Sicherheitsnachweisen muss klar dargestellt werden, wo die Sicherheitsleistung umgesetzt ist.[<=]

5.1.1.2 Durch Ereignisse ausgelöste Reaktionen

A_17425 -Reagiere auf LAN_IP_Changed

Wurde die IP-Adresse des LAN Interfaces geändert oder hat, bei aktiven DHCP Client, ein erfolgreiches DHCP_RENEW stattgefunden MUSS der Basis-Consumer den LAN-Adapter initialisieren.[<=]

A_17426 -Reagiere auf WAN_IP_Changed

Wurde die IP-Adresse des WAN Interfaces geändert oder hat, bei aktiven DHCP Client, ein erfolgreiches DHCP_RENEW stattgefunden MUSS der Basis-Consumer den WAN-Adapter initialisieren.[<=]

A_17430 -Netzwerk-Routen einrichten

Der Basis-Consumer MUSS die Konfiguration aller notwendigen Netzwerk-Routen ermöglichen.[<=]

A_17474-01 -Anzeige IP-Routinginformationen

Der Basis-Consumer MUSS über eine Schnittstelle die konfigurierten IP-Routen und die aktuelle IP-Routingtabelle mit mindestens folgenden Informationen anzeigen:

- Forwarding Status
- Zieladresse/Präfix
- Gateway (Next-Hop)
- Routing Typ

- Routing Preference

[<=]

Zur Bekanntmachung von Änderungen und Neuanschlüssen zu den, an die TI angeschlossenen, weiteren Anwendungen des Gesundheitswesens für den Datenaustausch (WANDA Smart) wird tagesaktuell eine Datei mit dem Namen "Bestandsnetze.xml" bereitgestellt (siehe dazu [gemSpec_KSR#9/Anhang C]). Die Datei liefert für alle angeschlossenen WANDA Smart einen Namen/ID, Netzwerkinformationen (IP-Adressen) und den für dieses Netz zu verwendenden DNS Server welcher dem DNS Forwarder des Basis-Consumer übergeben wird.

A_17576 -KSR lokalisieren

Der Basis-Consumer MUSS für die Lokalisierung des Konfigurationsdienstes der TI (KSR) die Möglichkeit der Lokalisierung des KSR durch DNS-Anfragen an den DNS-Forwarder DNS_SERVERS_TI zur Auflösung der SRV-RR und TXT-RR mit den Bezeichnungen „_ksrkonfig._tcp.ksr.<TOP_LEVEL_DOMAIN_TI>“ vorsehen. Der Basis-Consumer erhält damit URLs der Downloadpunkte des KSR für Konfigurationsdaten (MGM_KSR_KONFIG_URL).[<=]

A_17574 -Infrastruktur-Konfiguration aktualisieren

Der Basis-Consumer MUSS täglich seine Infrastruktur-Konfiguration aktualisieren. Der Basis-Consumer MUSS dazu eine TLS-Verbindung zum Konfigurationsdienst der TI aufbauen. Dabei MUSS er das durch den Server präsentierte Zertifikat prüfen. Das Herunterladen der Konfigurationsdaten erfolgt mittels I_KSRs_Download::get_Ext_Net_Config (MGM_KSR_KONFIG_URL, „Bestandsnetze.xml“.) [<=]

5.1.2 Zeitdienst

Der Zeitdienst schafft die Grundlage einer gleichen Systemzeit für alle in der TI einzusetzenden Produkttypen. Innerhalb des Basis-Consumers ist dafür ein NTP-Client erforderlich, welcher die Zeitangaben des Zeitdienstes der zentralen TI abfragt und verwendet. Die in [gemSpec_Net#6.2.2] „Nutzung“ getroffenen Anforderungen werden durch dieses Kapitel erweitert.

A_17485 -Maximale Zeitabweichung

Der Basis-Consumer MUSS sicherstellen, dass der maximale zulässige Fehler von +/- 20ppm (part per million) gegenüber einer Referenzuhr nicht überschritten wird. Dies entspricht einer maximalen Abweichung im Freilauf von +/- 34,56 Sekunden über 20 Tage.[<=]

5.1.3 Namensdienst und Dienstlokalisierung

5.1.3.1 Funktionsmerkmalweite Aspekte

A_17498 -Grundlagen des Namensdienstes

Der Basis-Consumer MUSS die Funktion eines Recursive Caching Nameservers zur Auflösung von DNS-Anfragen anbieten. (Im Folgenden kurz DNS-Server genannt). Der Caching-Nameserver des Basis-Consumer MUSS für Clientsysteme aus dem lokalen Netzwerk der Einsatzumgebung erreichbar sein. Der Caching Nameserver des Basis-Consumer MUSS einen sinnvollen Timeout für die Bearbeitung von DNS-Abfragen beachten. Konnte eine DNS-Abfrage nicht durchgeführt werden, MUSS die Bearbeitung abgebrochen werden.[<=]

A_17499 -DNS-Forwards des DNS-Servers

Der DNS-Server des Basis-Consumer MUSS die folgenden DNS-Forwards durchführen:

Tabelle 2: TAB_CONS_687 DNS-Forwards des DNS-Servers

Domain	Forwarders	Bemerkungen
Namensraum TI (*.DNS_TOP_LEVEL_DOMAIN_TI)	DNS_SERVERS_TI	DNS ForwardRule zur Auflösung aller DNS-Namen innerhalb des Namensraums der TI.
Namensraum angeschlossene Netze des Gesundheitswesens mit WANDA Basic (Domainnamen von angeschlossenen Netzen des Gesundheitswesens mit WANDA Basic gemäß Bestandsnetze.xml)	DNS_SERVERS_BESTANDSNETZE (Je Domainnamen eines angeschlossenen Netzes des Gesundheitswesens mit WANDA Basic alle zugehörigen DNS-Server IP-Adressen gemäß Bestandsnetze.xml)	Je angeschlossenem Netz des Gesundheitswesens mit WANDA Basic in NLW_AKTIVE_BESTANDSNETZE wird eine DNS ForwardRule zur Auflösung von DNS-Namen innerhalb dieses Netzes verwendet.
Namensraum lokale Einsatzumgebung	DNS_SERVERS_CONSUMER	DNS ForwardRule zur Auflösung aller DNS-Namen innerhalb der DNS-Domain im LAN des Consumer

[<=]

A_17500 -DNS Stub-Resolver

Der Basis-Consumer MUSS von allen internen Diensten zur Namensauflösung genutzt werden.

Der Stub-Resolver im Basis-Consumer MUSS immer den Caching Nameserver im Basis-Consumer anfragen.[<=]

5.1.3.2 Interne TUCs, auch durch Fachmodule nutzbar*5.1.3.2.1 TUC_CON_362 „Liste der Dienste abrufen“***A_17502 -TUC_CON_362 „Liste der Dienste abrufen“**

Der Basis-Consumer MUSS den technischen Use Case TUC_CONS_362 „Liste der Dienste abrufen“ umsetzen.

Tabelle 3: TAB_CONS_648 - TUC_CONS_362 „Liste der Dienste abrufen“

Element	Beschreibung
Name	TUC „Liste der Dienste abrufen“
Beschreibung	Ermittlung aller zu einer DNS-SD-Gruppe gehörenden DNS-Namen.
Auslöser	interne Anfrage (Basisdienst oder Fachmodul)

Vorbedingungen	Die vom Basis-Consumer zu verwendenden DNS-Server müssen konfiguriert sein.
Eingangsdaten	FQDN des PTR Resource Records
Komponenten	Basis-Consumer
Ausgangsdaten	LIST_OF_SRV_ENTITIES
Standardablauf	Mit dem FQDN wird eine Typ „PTR“ Anfrage an den Stub-Resolver des Basis-Consumer gestellt.

[<=]

5.1.3.3 Operationen an der Clientsystemschnittstelle

A_17509 -Basisanwendung Namensdienst

Der Basis-Consumer MUSS für Clients in der Einsatzumgebung und den Fachmodulen im jeweiligen Consumer eine Basisanwendung Namensdienst, mit der Funktion Namensauflösung und Dienstlokalisierung anbieten.

Tabelle 4: Basisanwendung Namensdienst

Name	Namensdienst	
Version	wird im Produktsteckbrief des Basis-Consumer definiert	
Namensraum	Keiner	
Namensraum-Kürzel	Keiner	
Operationen	Name	Kurzbeschreibung
	GetIPAddress	Diese Operation ermöglicht die Auflösung von FQDNs in IP-Adressen
WSDL	Keines	
Schema	Keines	

[<=]

5.1.3.4 Betriebsaspekte

A_17512-01 -Initialisierung „Namensdienst und Dienstlokalisierung“

Der Basis-Consumer MUSS in der Bootup-Phase zur Initialisierung des Funktionsmerkmals „Namensdienst und Dienstlokalisierung“ den Caching-Nameserver starten.

[<=]

A_17513-01 -Konfigurationsparameter Namensdienst und Dienstlokalisierung

Der Administrator des Basis-Consumer MUSS die aufgelisteten Parameter in Tabelle 5 über eine Schnittstelle konfigurieren und die aufgelisteten Parameter in Tabelle 6 ausschließlich einsehen können.

Nach jeder Änderung MUSS sichergestellt werden, dass die Änderungen sofort am autoritativen bzw. am Caching Nameserver zur Verfügung stehen.

Tabelle 5: Konfigurationsparameter Namensdienst

ReferenzID	Belegung	Bedeutung und Administrator-Interaktion
DNS_SERVERS_CONSUMER	Liste von IP-Adressen der DNS-Server	Liste von DNS-Servern, die zur Namensauflösung von Namensräumen in der Einsatzumgebung verwendet werden. Der Administrator MUSS die Liste von DNS-Servern, die die DNS_DOMAIN_CONSUMER auflösen, bearbeiten können. Die IP-Adressen der DNS-Server KÖNNEN auf den Adressbereich der ANLW_LAN_IP_ADDRESS eingeschränkt sein.
DNS_DOMAIN_CONSUMER	DNS Domainname	DNS Domainname, der von einem DNS-Server der Einsatzumgebung aufgelöst wird. Der Name DARF NICHT mit einem „.“ beginnen.

Tabelle 6: Einsehbare Konfigurationsparameter Namensdienst

ReferenzID	Belegung	Bedeutung
DNS_SERVERS_TI	Liste von IP-Adressen der DNS-Server	Liste von DNS-Servern, die zur Namensauflösung des Namensraums der TI verwendet werden
DNS_TOP_LEVEL_DOMAIN_TI	DNS Domainname	Top Level Domain des Namensraumes TI

[<=]

5.2 Sicherheit

Die Sicherheits- und Datenschutzanforderungen sind abgedeckt durch die übergreifenden Sicherheits- und Datenschutzanforderungen an Hersteller und Anbieter [gemSpec_DS_Hersteller], [gemSpec_DS_Anbieter], die spezifischen Sicherheits- und Datenschutzanforderungen des Clientmoduls KOM-LE im Basis-Consumer [gemSpec_CM_KOMLE] sowie die spezifischen Sicherheits- und Datenschutzanforderungen der Systemprozesse der dezentralen TI [gemSpec_Systemprozesse_dezTI].

5.3 Identitäten

In diesem Dokument werden kryptographische Identitäten entsprechend ihrer Bezeichner im Objektsystem der SMC-B referenziert. Dies dient der Eindeutigkeit der Referenz und bedeutet nicht, dass die Strukturen des Objektsystems der SMC-B in einem HSM nachgebildet werden müssen.

Im Basis-Consumer werden private Schlüssel der SMC-B in einem HSM oder auf einer SMC-B in Kartenform gespeichert. Das Schlüsselmaterial des KOM-LE-Clientmoduls hingegen wird auch hier in einem HSM gespeichert.

Nachfolgend wird festgelegt, welche Qualitäten dabei erreicht werden müssen und was bei der Personalisierung zu beachten ist.

A_17598 -Qualität des HSM

Die Basis-Consumer MÜSSEN privates Schlüsselmaterial zu Zertifikaten der Telematikinfrastruktur in einem HSM, dessen Eignung durch eine erfolgreiche Evaluierung nachgewiesen wurde, integritätsgeschützt und vertraulich speichern. Als Evaluierungsschema kommen dabei Common Criteria oder Federal Information Processing Standard (FIPS) in Frage. Die Prüftiefe MUSS mindestens (a) FIPS 140-2 Level 3, oder (b) Common Criteria EAL 4 entsprechen. [≤]

A_24024 -HSM - Sicherer Zugriff auf Identitäten

Der Basis-Consumer MUSS privates Schlüssel der TI-Identitäten der Nutzer des Consumers im HSM eindeutig referenzieren und durchsetzen, dass Nutzer des Consumers jeweils genau nur Ihre Identitäten (private Schlüssel) verwenden können. [≤]

A_24025 -Authentisierte, vertrauliche und integritätsgeschützte Kommunikation

Der Basis-Consumer MUSS durchsetzen, dass Operationsaufrufe zu einem HSM nur nach Authentisierung gegenüber dem HSM und unter Wahrung von Vertraulichkeit und Integrität stattfinden, sodass Unberechtigte weder Schlüssel auf dem HSM nutzen können, noch die Kommunikation mit dem HSM abhören oder manipulieren können. Die Maßnahmen dienen primär dem sicheren Betrieb des HSMs, MÜSSEN aber ebenso eine sichere Personalisierung (A_17599*) ermöglichen bzw. unterstützen. [≤]

A_18195 -Basis-Consumer mit SMC-B

Der Basis-Consumer KANN privates Schlüsselmaterial einer SMC-B in Kartenform nutzen. [≤]

Tabelle 7: Tab_Personalisierung_HSM - Personalisierung des HSM

Aspekt	Beschreibung
Schlüsselmaterial der SMC-B	Das Schlüsselmaterial wird sicher im HSM erzeugt. Das private Schlüsselmaterial verlässt das HSM nicht oder nur zum Zwecke eines Backups auf einem Backup-HSM, wobei die Übertragung hinsichtlich Vertraulichkeit geschützt sein muss.
Zertifikatsrequest	Die benötigten Zertifikatsrequests werden im HSM erzeugt und exportiert. Die Zertifikatsrequests werden unter Wahrung der Authentizität und Integrität dem TSP übermittelt.
Zertifikat	Das Zertifikat wird vom TSP zum Betreiber übermittelt.

Hinweis:

- Ein Basis-Consumer verwendet SM(C)-B-ORG-Schlüsselmaterial gemäß [gemSpec_PKI#10.6] mit Ausnahme des Basis-Consumers für Kostenträger, der SM(C)-B-KTR Schlüsselmaterial gemäß [gemSpec_PKI#10.4] mit der ProfessionOID „oid_kostentraeger“ verwendet.
- Ein Basis-Consumer für Kostenträger verwendet SMC-B-KTR Schlüsselmaterial gemäß [gemSpec_PKI#10.4]. Dieses kann in den Ausprägungen oid_kostentraeger oder oid_ombudsstelle auftreten.

A_17599 -Personalisierung des HSM

Der Anbieter des Basis-Consumers MUSS einen sicheren Prozess zur Personalisierung des HSMs definieren und etablieren, der die in Tab_Personalisierung_HSM genannten Aspekte beinhaltet. [≤]

A_24026 -Der Anbieter des Basis-Consumers SOLL private Schlüssel für KIM-CM-TLS...

Der Anbieter des Basis-Consumers SOLL private Schlüssel für KIM-CM-TLS-Zertifikate vor unberechtigtem Zugriff geschützt im HSM (siehe A_17598*) speichern, nachdem er sie vom KIM-Anbieter erhalten hat. [≤]

Eine Abweichung von Anforderung A_24026* ist gestattet für den Fall, dass entsprechend A_18195* kein HSM eingesetzt wird.

A_18196 -Personalisierung des HSM beim Basis-Consumer

Der Anbieter eines Basis-Consumers, der ausschließlich mit SMC-Bs in Kartenform arbeitet, KANN auf einen Prozess zur Personalisierung der Identitäten der SMC-B im HSM verzichten. [≤]

A_25030 -Informierte Identitätswahl bei Nutzung von Operationen mit CardHandle Parameter

Der Anbieter des Basis-Consumer MUSS sicherstellen, dass dem clientseitigen Nutzer jederzeit die Möglichkeit zur Verfügung gestellt wird zu wählen, mit welcher der ihm zugeordneten Identitäten die Consumer Operationen aufgerufen werden. Dabei MÜSSEN dem Nutzer eindeutig für jede Identität die in TAB_CardHandle_Map enthaltenen Informationen zugeordnet werden.

Ungültige oder vom Identitätsträger (HSM) entfernte Identitäten DÜRFEN dem Nutzer dabei NICHT zur Verfügung gestellt werden.

Tabelle 8: TAB_CardHandle_Map

Information	Beschreibung
CardHandle	Handle, mit dem die Identität in Folgeaufrufen adressiert werden kann. Der Anbieter garantiert, dass dieses Handle die Identität eindeutig identifiziert und bei Entfernen der Identität vom Identitätsträger (HSM) ungültig wird.
Typ der Identität	Mögliche Werte sind: • SM-B-KTR • SM-B-ORG • SMC-B-KTR • SMC-B-ORG
Name des Identitätsinhabers bzw. der Institution/Organisation	subject.commonNameaus [gemSpec_OID#10.10] bzw. [gemSpec_OID#10.4]
Profession OID	professionOIDnach [gemSpec_OID#10.10] bzw. [gemSpec_OID#10.4] (extensions.admission.professionOID)
Telematik-ID	Telematik-ID nach [gemSpec_OID#10.10] bzw. Telematik-

	ID nach [gemSpec_OID#10.4] (extensions.admission.registrationNumber)
--	---

[<=]

5.4 Schnittstellen

Für den Basis-Consumer werden einheitliche Schnittstellen definiert und im Rahmen des Zulassungstests genutzt. Für eine bessere Integrationsfähigkeit ist es aber erlaubt, dass zusätzlich zu den definierten Schnittstellen auch weitere Schnittstellentechnologien genutzt werden können, über welche die festgelegten Operationen angesprochen werden können.

A_17712 -Zusätzlich alternative Schnittstellentechnologien

Der Basis-Consumer KANN zusätzlich zu den in den Spezifikationen festgelegten Schnittstellen zusätzlich weitere Schnittstellentechnologien anbieten, über welche die festgelegten Operationen angesprochen werden können.[<=]

6 Funktionsmerkmale

6.1 Verschlüsselungsdienst

6.1.1 Durch Module nutzbare TUCs

A_17466 -Systemprozess PL_TUC_HYBRID_ENCIPHER

Der Basis-Consumer MUSS den Systemprozess PL_TUC_HYBRID_ENCIPHER implementieren und bereitstellen.[<=]

A_17467 -Systemprozess PL_TUC_HYBRID_DECIPHER

Der Basis-Consumer MUSS den Systemprozess PL_TUC_HYBRID_DECIPHER implementieren und bereitstellen.[<=]

6.1.2 Operationen an der Clientsystemschnittstelle

A_17477 -Basisdienst Verschlüsselungsdienst

Der Basis-Consumer MUSS für Clients einen Basisdienst Verschlüsselungsdienst anbieten.

Tabelle 9: Tab_Verschlüsselungsdienst

Name	EncryptionService	
Version	Siehe Anhang	
Namensraum	Siehe Anhang	
Namensraum-Kürzel	CRYPT für Schema und CRYPTW für WSDL	
Operationen	Name	Kurzbeschreibung
	EncryptDocument	Dokument hybrid verschlüsseln
	DecryptDocument	Dokument hybrid entschlüsseln
WSDL	EncryptionService.wsdl	
Schema	EncryptionService.xsd	

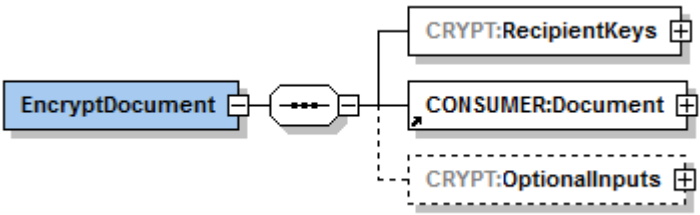
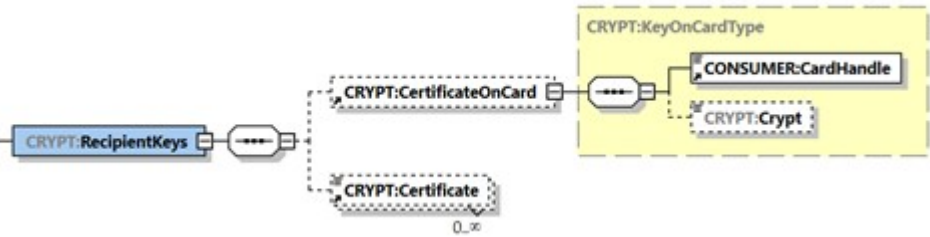
[<=]

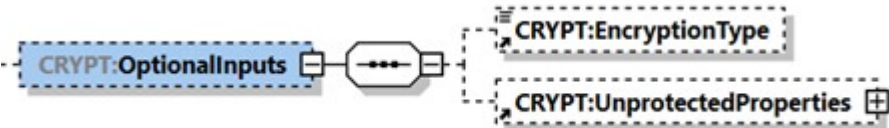
6.1.2.1 EncryptDocument

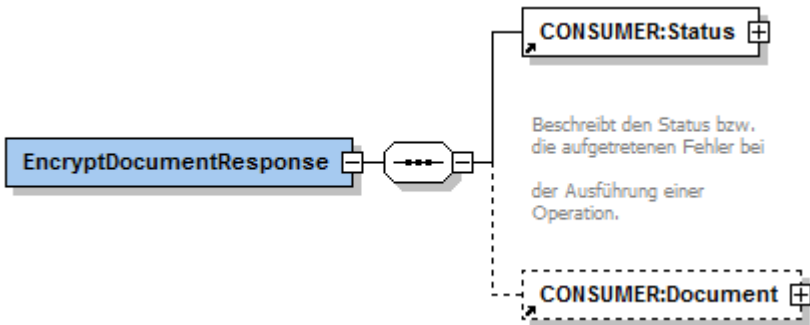
A_17510-05 -Basis-Consumer, Operation EncryptDocument

Der Verschlüsselungsdienst des Basis-Consumer MUSS an der Clientsystemschnittstelle eine Operation EncryptDocument anbieten.

Tabelle 10: Tab_Operation_EncryptDocument

Name	EncryptDocument						
Beschreibung	Diese Operation verschlüsselt ein übergebenes Dokument hybrid. Der Dokumententyp XML wird gesondert behandelt. Alle anderen Dokumententypen nutzen die binäre Verschlüsselung. Für die hybride Verschlüsselung wird ein asymmetrischer Schlüssel aus einem X.509v3-Zertifikat genutzt. Dieses Zertifikat wird als Parameter übergeben oder auf dem HSM referenziert. Pro Operationsaufruf können mehrere Hybridschlüssel erzeugt werden. Durch das Zertifikat wird festgelegt, ob RSA oder ECC basierte Hybridschlüssel erzeugt werden. Bei Angabe der Zertifikate überCertificateOnCard(Referenz auf HSM) wird ausschließlich das Verschlüsselungsverfahren ECC über die KeyReference EF.C.HCI.ENC.E256verwendet. Für alle Dokumententypen wird immer das gesamte Dokument verschlüsselt.						
Aufrufparameter	  <table border="1" data-bbox="387 1563 1385 2013"> <tr> <td data-bbox="387 1563 555 1787">Recipient Keys</td><td data-bbox="563 1563 1385 1787">Identifiziert die Empfänger der zu verschlüsselnden Nachricht über X.509-Zertifikate (öffentliche Schlüssel). Quelle für die Zertifikate kann eine Karte sein, die per CertificateOnCard-Element referenziert wird, oder der Aufrufer, der X.509-Zertifikate im Certificate-Element übergibt.</td></tr> <tr> <td data-bbox="387 1787 555 1955">CardHandle</td><td data-bbox="563 1787 1385 1955">Identifiziert die zu verwendende Karte mit dem (öffentlichen) Schlüssel. Ist das Element nicht vorhanden, so werden nur Zertifikate per ElementCertificateübergeben.</td></tr> <tr> <td data-bbox="387 1955 555 2013">Crypt</td><td data-bbox="563 1955 1385 2013">Der Parameter wird nicht ausgewertet - Optional;</td></tr> </table>	Recipient Keys	Identifiziert die Empfänger der zu verschlüsselnden Nachricht über X.509-Zertifikate (öffentliche Schlüssel). Quelle für die Zertifikate kann eine Karte sein, die per CertificateOnCard-Element referenziert wird, oder der Aufrufer, der X.509-Zertifikate im Certificate-Element übergibt.	CardHandle	Identifiziert die zu verwendende Karte mit dem (öffentlichen) Schlüssel. Ist das Element nicht vorhanden, so werden nur Zertifikate per ElementCertificateübergeben.	Crypt	Der Parameter wird nicht ausgewertet - Optional;
Recipient Keys	Identifiziert die Empfänger der zu verschlüsselnden Nachricht über X.509-Zertifikate (öffentliche Schlüssel). Quelle für die Zertifikate kann eine Karte sein, die per CertificateOnCard-Element referenziert wird, oder der Aufrufer, der X.509-Zertifikate im Certificate-Element übergibt.						
CardHandle	Identifiziert die zu verwendende Karte mit dem (öffentlichen) Schlüssel. Ist das Element nicht vorhanden, so werden nur Zertifikate per ElementCertificateübergeben.						
Crypt	Der Parameter wird nicht ausgewertet - Optional;						

	Certificate	Certificate ist ein Base64-kodiertes XML-Element, in dem das Zertifikat, das den asymmetrischen Schlüssel enthält (öffentlicher Schlüssel), DER-kodiert übergeben wird. Es kann eine Liste von Zertifikaten übergeben werden. Dieses Element kann leer sein, wenn ausschließlich Zertifikate verwendet werden sollen, die über CertificateOnCard angegeben werden.
	CONSUMER: Document	Dieses entsprechend [OASIS-DSS] Section 2.4.2 spezifizierte Element enthält das zu verschlüsselnde Dokument, wobei das Kindelement <code>dss:Base64Data</code> oder <code>CONSUMER:Base64XML</code> verwendet wird. Das zugeordnete Verschlüsselungsverfahren ist • XMLEnc: „http://www.w3.org/TR/xmlenc-core/“ für <code>CONSUMER:Base64XML</code> • CMS: „urn:ietf:rfc:5652“ für <code>dss:Base64Data</code>
		
	CRYPT: Optional Inputs	Enthält die optionalen Parameter <code>CRYPT:UnprotectedProperties</code> und <code>CRYPT:EncryptionType</code>.
	Encryption Type	Dieses optionale Element bestimmt das Verschlüsselungsverfahren. Es MUSS das Verfahren XMLEnc: „http://www.w3.org/TR/xmlenc-core/“ unterstützt werden, wenn das Dokument in <code>CONSUMER:Base64XML</code> übergeben wird und CMS: „urn:ietf:rfc:5652“, wenn das Dokument in <code>dss:Base64Data</code> übergeben wird. Die Verwendung dieses Elements ist aufgrund der impliziten Zuordnung der Verschlüsselungsverfahren zur Methode der Dokumentübergabe nicht erforderlich.
	CRYPT: Unprotected Properties	Dieses optionale Element wird nur für das Verschlüsselungsverfahren CMS ausgewertet (zu verschlüsselndes Dokument ist in <code>dss:Base64Data</code> vorhanden). Die Elemente <code>./UnprotectedProperties/Property/Value/CM</code> SAttributemüssen base64/DER-kodiert ein vollständiges ASN.1-Attribut enthalten, definiert in [CMS# 9.1.AuthenticatedData Type]. Es muss bei der Erstellung des CMS-Containers unter "unauthAttrs" aufgenommen werden. Das zugehörige Element <code>./UnprotectedProperties/Property/Identifie</code>

		rwird nicht ausgewertet.
Rückgabe		
	Status	Enthält den Ausführungsstatus der Operation.
	Document	Enthält das verschlüsselte Dokument in Base64-codierter Form, wenn die Verschlüsselung erfolgreich durchgeführt wurde. Im Fall XMLEnc wird das verschlüsselte XML-Dokument in CONSUMER:Document/CONSUMER:Base64XML zurückgegeben. Im Fall CMS wird das verschlüsselte Dokument in CONSUMER:Document/dss:Base64data zurückgegeben.
Vorbedingungen	Keine	
Nachbedingungen	Keine	

Vor der Verwendung für die Verschlüsselung MÜSSEN Zertifikate durch den Aufruf von PL_TUC_PKI_VERIFY_CERTIFICATE auf ihre Gültigkeit geprüft werden.
Abgelaufene oder gesperrte Zertifikate MÜSSEN von der Verwendung ausgeschlossen werden.

Das Verschlüsseln erfolgt durch Aufruf von PL_TUC_HYBRID_ENCIPHER {
Doc, das zu verschlüsselnde Dokument = CONSUMER:Document;
{Cert(i)}, „Menge der Empfänger-/Ziel-Zertifikate“ = RecipientKeys;
Attribute, optionale, zusätzliche Attribute = UnprotectedProperties;
}

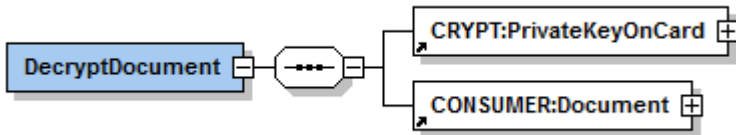
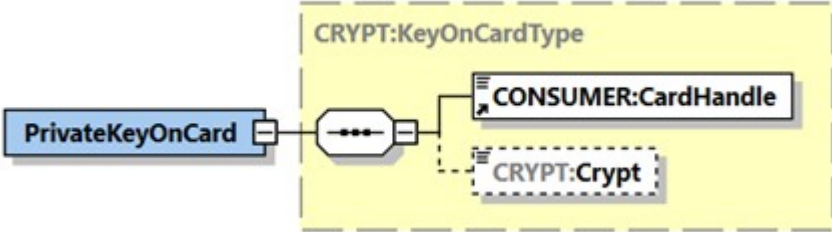
Wird ein Zertifikat per CertificateOnCard-Element referenziert, ist dieses vorher durch den HSMProxy zu extrahieren[<=]

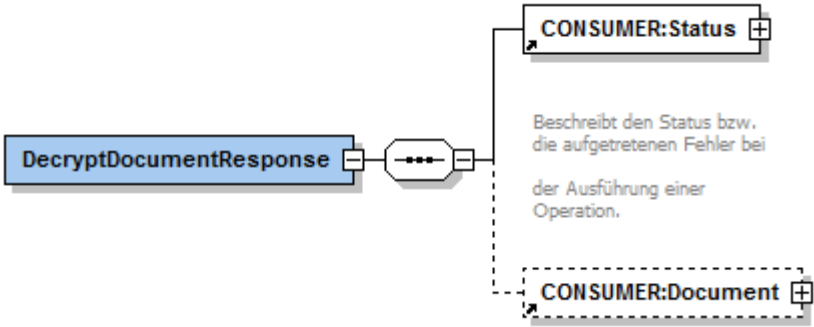
6.1.2.2 DecryptDocument

A_17515-03 -Basis-Consumer, Operation DecryptDocument

Der Verschlüsselungsdienst des Basis-Consumer MUSS an der Clientsystemschnittstelle eine Operation DecryptDocument anbieten.

Tabelle 11: Tab_Operation_DecryptDocument

Name	DecryptDocument	
Beschreibung	Diese Operation entschlüsselt ein hybrid verschlüsseltes Dokument. Es werden die Dokumententypen XML und Andere (Binär) unterstützt. Für die Entschlüsselung wird ein asymmetrischer Schlüssel zu einem X.509v3-Zertifikat genutzt. Das Kryptoverfahren (RSA oder ECC) wird durch den Hybridschlüssel des verschlüsselten Dokuments bestimmt. Liegt eine Verschlüsselung sowohl für RSA, als auch ECC vor, erfolgt vorrangig eine Entschlüsselung mittels des ECC-Schlüssels.	
Aufrufparameter		
		
	PrivateKeyOnCard	Identifiziert die zu verwendende Karte mit dem (privaten) Schlüssel.
	CardHandle	Identifiziert die Karte.
	Crypt	Wird nicht verwendet. Die Auswahl des Kryptoverfahrens erfolgt anhand des Hybridschlüssels des verschlüsselten Dokuments..
	CONSUMER: Document	Enthält das base64-codierte Dokument, das entschlüsselt werden soll.

Rückgabe	 The diagram shows a blue box labeled 'DecryptDocumentResponse' connected to a circle containing three dots. This circle is connected to two boxes: 'CONSUMER:Status' (solid) and 'CONSUMER:Document' (dashed). A text block between them reads: 'Beschreibt den Status bzw. die aufgetretenen Fehler bei der Ausführung einer Operation.'	
	Status	Enthält den Ausführungsstatus der Operation.
	Document	Enthält das entschlüsselte Dokument in Base64-codierter Form. Im Fall der Verschlüsselung mit XMLEnc wird das entschlüsselte XML-Dokument in CONSUMER:Document/CONSUMER:Base64XML zurückgegeben. Im Fall der Verschlüsselung mit CMS wird das entschlüsselte Dokument in CONSUMER:Document/dss:Base64data zurückgegeben.
Vorbedingungen	Keine	
Nachbedingungen	Keine	

Das Entschlüsseln erfolgt durch Aufruf von PL_TUC_HYBRID_DECIPHER {
D, "das verschlüsselte Dokument =CONSUMER:Document;
Id, "(Identität des) Empfänger" =PrivateKeyOnCard;
} [≤]

6.2 Signaturdienst

A_23999 -Ergebnis der Signaturprüfung einer KOM-LE-Nachricht

Der Basis-Consumer KANN als Ergebnis der Signaturprüfung der KOM-LE-Nachricht eine Datei mit einem detaillierten Signaturprüfungsbericht als Anhang in die Nachricht einfügen. Der Name der Datei MUSS sich aus dem Wort "*Signaturprüfungsbericht*" und dem aktuellen minutengenauen Zeitstempel zusammensetzen. Es ist folgendes Format des Dateinamens gemäß ISO 8601 anzuwenden: *Signaturpruefungsbericht_JJJJMMTT_hhmm*. [≤]

6.2.1 Durch Module nutzbare TUCs

A_17517 -Systemprozess PL_TUC_SIGN_DOCUMENT_nonQES

Der Basis-Consumer MUSS den Systemprozess PL_TUC_SIGN_DOCUMENT_nonQES implementieren und bereitstellen. [≤]

A_17518 -Systemprozess PL_TUC_SIGN_HASH_nonQES

Der Basis-Consumer MUSS den Systemprozess PL_TUC_SIGN_HASH_nonQES implementieren und bereitstellen.【<=】

A_17577 -Systemprozess PL_TUC_VERIFY_DOCUMENT_nonQES

Der Basis-Consumer MUSS den Systemprozess PL_TUC_VERIFY_DOCUMENT_nonQES implementieren und bereitstellen.【<=】

6.2.2 Operationen an der Clientsystemschnittstelle

A_17523 -Basisdienst Signaturdienst

Der Basis-Consumer MUSS Clientsystemen einen Basisdienst Signaturdienst (nonQES) anbieten.

Tabelle 12: Tab_Signaturdienst

Name	SignatureService	
Version	Siehe Anhang	
Namensraum	Siehe Anhang	
Namensraum-Kürzel	SIG für Schema und SIGW für WSDL	
Operationen	Name	Kurzbeschreibung
	SignDocument	Dokument signieren
	VerifyDocument	Signatur verifizieren
	ExternalAuthenticate	Binärstring signieren
WSDL	SignatureService.wsdl	
Schema	SignatureService.xsd	

【<=】

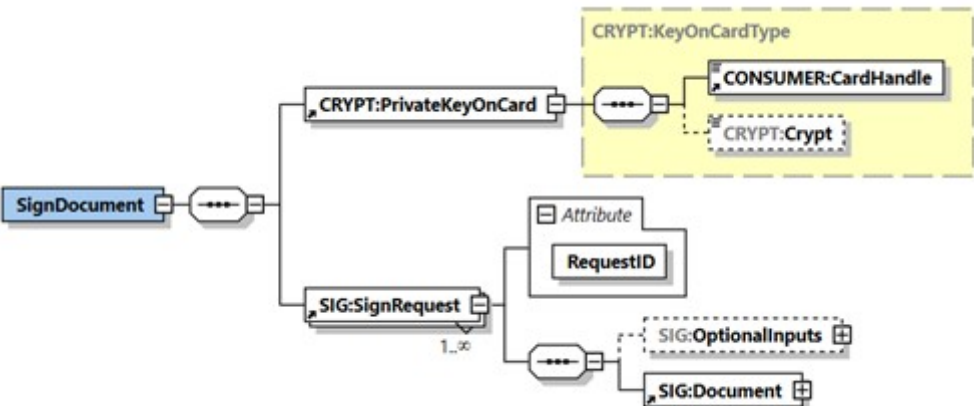
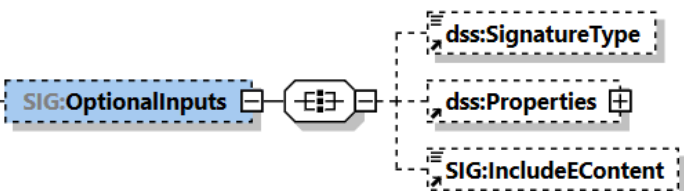
6.2.2.1 SignDocument

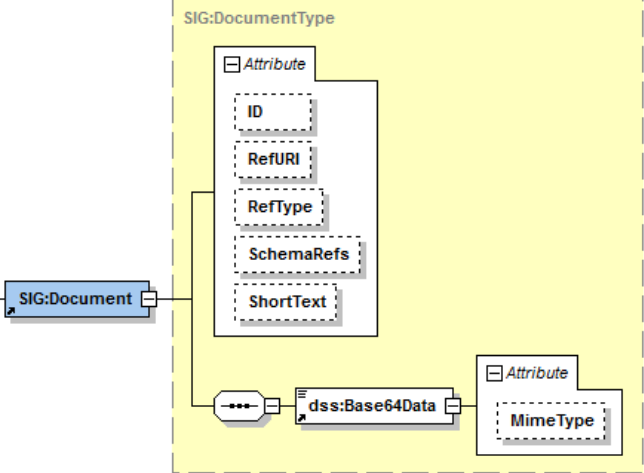
A_17525-04 -Basis-Consumer, Operation SignDocument

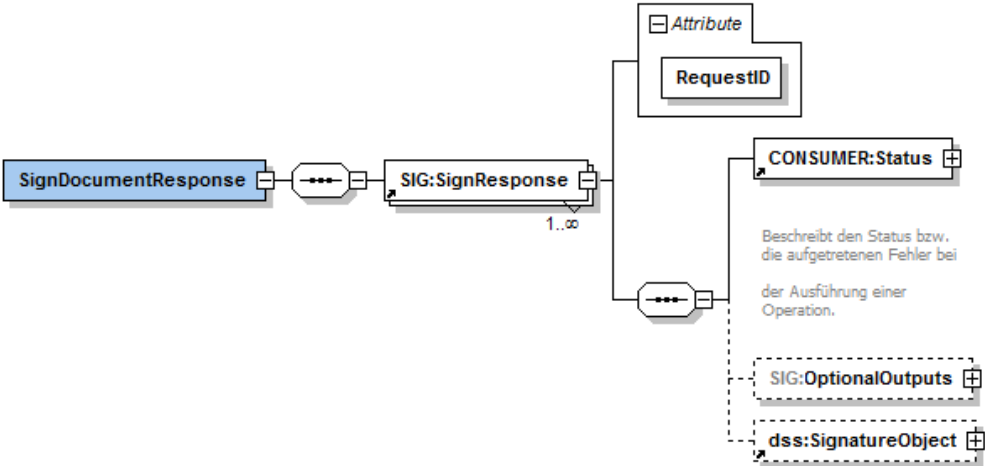
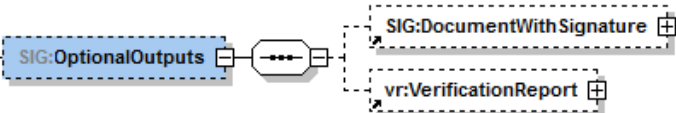
Der Signaturdienst des Basis-Consumer MUSS an der Clientsystemschnittstelle eine an [OASIS-DSS] angelehnte Operation SignDocument wie in Tabelle Tab_Operation_SignDocument beschrieben anbieten.

Tabelle 13: Tab_Operation_SignDocument

Name	SignDocument
Beschreibung	Diese Operation lehnt sich an [OASIS-DSS] an. Sie enthält voneinander unabhängige SignRequests. Jeder SignRequest erzeugt eine Signatur für ein Dokument. Zur Signaturerzeugung werden Schlüssel und Zertifikate eines HSM benutzt. Es wird ausschließlich der Signaturtyp "CMS-Signatur" gemäß

	[RFC 5652] (URIurn:ietf:rfc:5652) und das Profil CAdES-BES gemäß[CAdES] verwendet.	
Aufruf- parameter		
	PrivateKeyOnCard	Identifiziert die zu verwendende Karte mit dem (privaten) Schlüssel.
	CardHandle	Identifiziert die zu verwendende Signaturkarte.
	Crypt	Der Parameter wird nicht ausgewertet - Optional; Es muss ausschließlich ECC über die KeyReferencePrK.HCI.OSIG.E256 verwendet werden. Der Schlüssel der Referenz PrK.HCI.OSIG.R2048 DARF NICHT verwendet werden.
	SIG:SignRequest	EinSignRequestkapselt den Signaturauftrag für ein Dokument. Das verpflichtende XML-AttributRequestIDidentifiziert einenSignRequestinnerhalb eines Stapels vonSignRequestseindeutig. Es dient der Zuordnung derSignResponsezum jeweiligenSignRequest.
	SIG:OptionalInputs	Enthält optionale Eingangsparameter (angelehnt andss:OptionalInputsgemäß [OASIS-DSS] Section 2.7): 

SIG:Document	 Dieses an das dss:DocumentElement aus [OASIS-DSS] Section 2.4.2 angelehnte Element enthält das zu signierende Dokument in dss:Base64Data.
dss:SignatureType	Durch dieses in [OASIS-DSS] (Abschnitt 3.5.1) beschriebene Element kann der generelle Typ der zu erzeugenden Signaturen angegeben werden. Es muss der Signatortyp CMS-Signatur (URI urn:ietf:rfc:5652) unterstützt werden. Fehlt dieses Element, so muss der Signatortyp CMS-Signatur (URI urn:ietf:rfc:5652) implizit verwendet werden.
dss:Properties	Durch dieses in [OASIS-DSS] (Abschnitt 3.5.5) definierte Element können zusätzliche signierte und unsignierte Eigenschaften (Properties) bzw. Attribute in die Signatur eingefügt werden. Es dürfen genau die folgenden Attribute ./SignedProperties/Property/Value/CMSAttribute - und ./UnsignedProperties/Property/Value/CMSAttribute enthalten sein. Ein solches XML-Element CMSAttribute muss ein vollständiges, base64/DER-kodiertes ASN.1-Attribute enthalten, definiert in [CMS#5.3.SignerInfo Type]. Es muss bei der Erstellung des CMS-Containers unverändert unter SignedAttributes bzw. UnsignedAttributes aufgenommen werden.
SIG:IncludeEContent	Durch dieses in [OASIS-DSS] (Abschnitt 3.5.7), definierte Element kann bei einer CMS-basierten Signatur das Einfügen des signierten Dokumentes in die Signatur angefordert werden. Fehlt dieses Element oder ist der Wert = "false",

		wird die Signaturvariante "detached" verwendet, ansonsten "enveloping".
Rückgabe		
	SIG:SignResponse	Eine SignResponse kapselt den ausgeführten Signaturauftrag pro Dokument. Die Zuordnung zwischen SignRequest und SignResponse erfolgt über die RequestID.
	CONSUMER:Status	Enthält den Status der ausgeführten Operation pro SignRequest.
	SIG:OptionalOutputs	Enthält optionale Ausgangsparameter. Dieses Element wird durch den Basis-Consumer nicht befüllt.
		
	SIG:DocumentWithSignature	Dieses Element wird durch den Basis-Consumer nicht befüllt.
	vr:VerificationReport	Dieses Element wird durch den Basis-Consumer nicht befüllt.

	dss:SignatureObject	Enthält im Erfolgsfall die erzeugte Signatur in Form eines dss:SignatureObject-Elements gemäß [OASIS-DSS] (Abschnitt 3.2). Der Signaturwert wird im XML-Element dss:SignatureObject/dss:Base64Signature übergeben. Der Signatur-Typ (CMS Signatur) in dss:SignatureObject/dss:Base64Signature/@Type Die XML-Elemente dss:SignatureObject/ds:Signature dss:SignatureObject/dss:Timestamp dss:SignatureObject/dss:SignaturePtr dss:SignatureObject/dss:Other werden nicht verwendet.
Vorbedingungen	Keine	
Nachbedingungen	Keine	

Das Signieren erfolgt durch Aufruf von PL_TUC_SIGN_DOCUMENT_nonQES {
IDENTIFIKATOR = PrivateKeyOnCard;
DOKUMENT = SIG:Document;
DOKUMENTTYPE = dss:SignatureType;
}[<=]

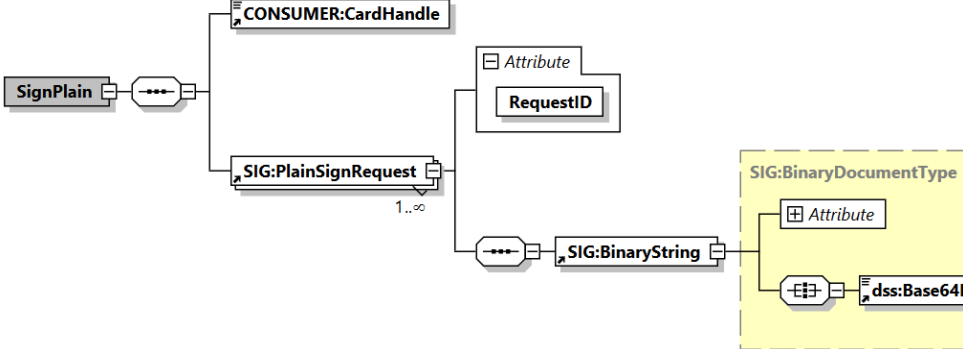
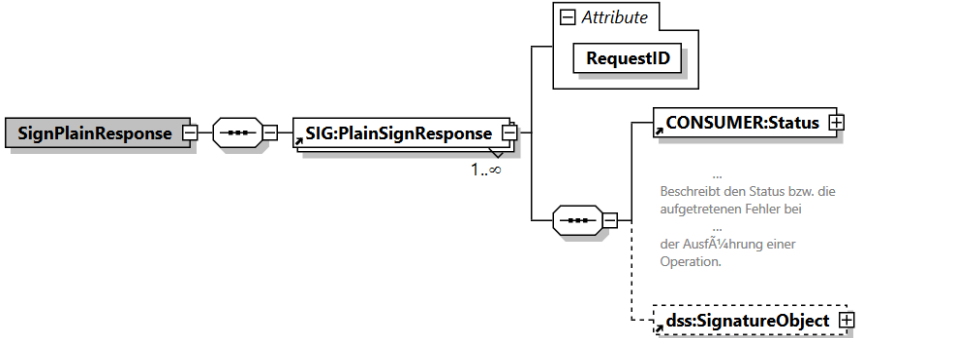
6.2.2.2 SignPlain

A_27048-01 -Basis-Consumer, Operation SignPlain

Der Signatordienst des Basis-Consumers MUSS an der Clientsystemschnittstelle eine an [OASIS-DSS] angelehnte Operation SignPlain, wie in Tabelle Tab_Operation_SignPlain beschrieben, anbieten.

Tabelle 14: Tab_Operation_SignPlain

Name	SignPlain
Beschreibung	Diese Operation lehnt sich an [OASIS-DSS] an. Sie enthält voneinander unabhängige PlainSignRequests. Jeder PlainSignRequest erzeugt eine Signatur für eine Bytefolge beliebiger Länge. Die Signaturerstellung erfolgt gemäß [BSI-TR-03111]#4.2.1 (URLurn:bsi:tr:03111:ecdsa). Es wird lediglich der übergebene Binärstring signiert. Eine Signatur über Metadaten wird nicht durchgeführt. Es MUSS ausschließlich ECC über die KeyReferencePrK.HCI.OSIG.E256 verwendet werden. Der Schlüssel der Referenz PrK.HCI.OSIG.R2048 DARF NICHT verwendet werden.

Aufruf- parameter	
CardHandle	Identifiziert die zu verwendende Signaturkarte.
SIG:PlainSignRequest	EinPlainSignRequest kapselt den Signaturauftrag für eine Bitfolge. Das verpflichtende XML-Attribut RequestID identifiziert einenPlainSignRequest innerhalb eines Stapels vonPlainSignRequest eindeutig. Es dient der Zuordnung derPlainSignResponse zum jeweiligenPlainSignRequest.
SIG:BinaryString	Dieses Element enthält im Kindelement dss:Base64Data den zu signierenden Binärstring. Das XML Attribut SIG:BinaryString/dss:Base64Data/@MimeType MUSS den Wert "application/octet-stream" haben. Als Signaturverfahren wird ausschließlich ECDSA unterstützt. Für die Signaturerstellung gilt: Es erfolgt die Signaturerstellung gemäß [BSI-TR-03111]#4.2.1. Als Eingangsparameter wird der Hash der zu signierenden Daten vom Aufrufer in SIG:BinaryString übergeben.
Rückgabe	
SIG:PlainSignResponse	EinePlainSignResponse kapselt den ausgeführten Signaturauftrag pro Bitfolge. Die Zuordnung zwischenPlainSignRequest undPlainSignResponse erfolgt über die

		RequestID .
	CONSUMER:Status	Enthält den Status der ausgeführten Operation pro Signaturauftrag.
	dss:SignatureObject	Enthält im Erfolgsfall die erzeugte Signatur in Form eines dss:SignatureObject-Elements gemäß [OASIS-DSS] (Abschnitt 3.2). Der Signaturwert wird im XML-Element dss:SignatureObject/dss:Base64Signature reübergaben. Das XML-Element dss:SignatureObject/dss:Base64Signature/@Type enthält den Signatur-Typ ECDSA (kennzeichnet durch den Wert urn:bsi:tr:03111:ecdsa). Die XML-Elemente dss:SignatureObject/ds:Signature dss:SignatureObject/dss:Timestamp dss:SignatureObject/dss:SignaturePtr dss:SignatureObject/dss:Other werden nicht verwendet.
Vorbedingungen	Keine	
Nachbedingungen	Keine	

Das Signieren erfolgt für jeden PlainSignRequest durch Aufruf von
 PL_TUC_SIGN_HASH_nonQES {
 IDENTIFIKATOR = CardHandle;
 SIGNATURVERFAHREN = ECDSA mit SHA-256;
 HASHWERT = PlainSignRequest.BinaryString;
 }

[<=]

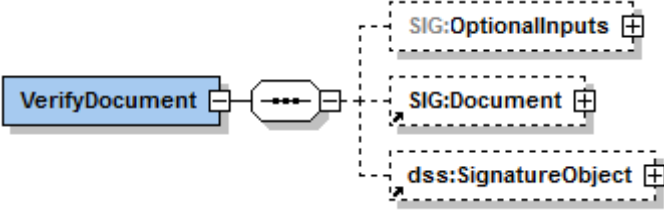
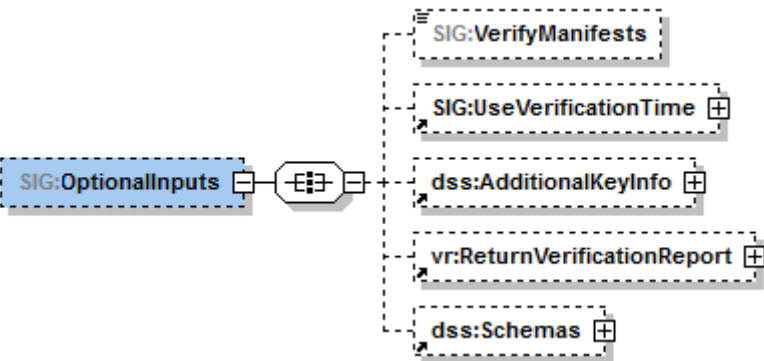
6.2.2.3 VerifyDocument

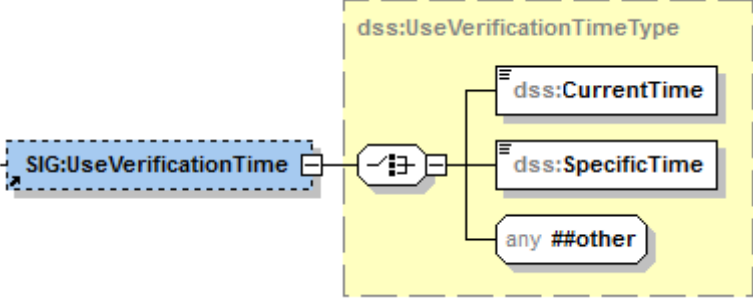
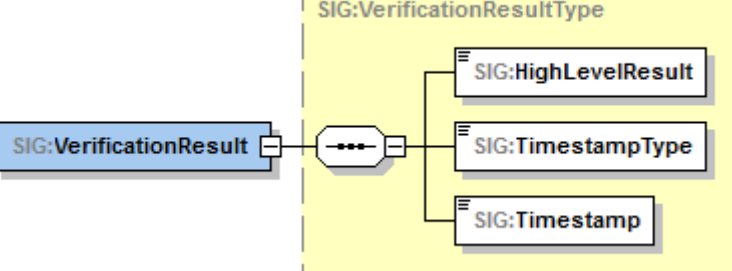
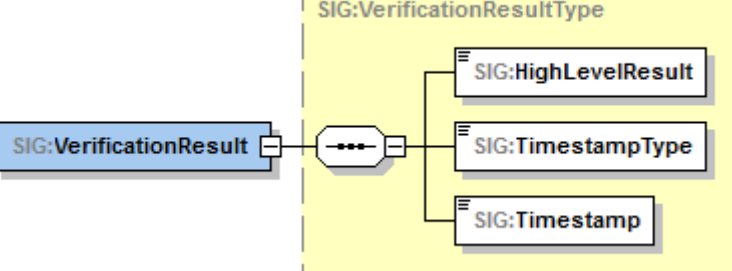
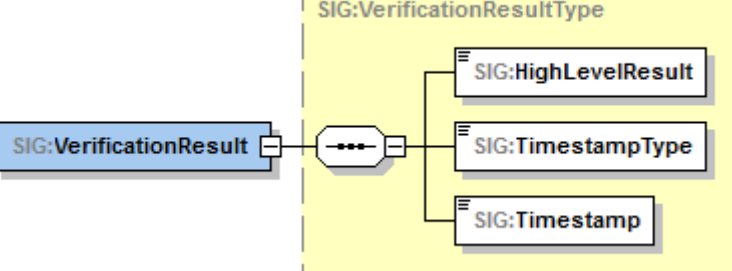
A_17526-03 -Basis-Consumer, Operation VerifyDocument

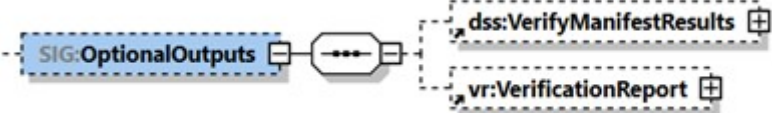
Der Signaturdienst des Basis-Consumer MUSS an der Clientsystemschnittstelle eine Operation VerifyDocument wie in Tabelle Tab_Operation_VerifyDocument beschrieben anbieten.

Tabelle 15: Tab_Operation_VerifyDocument

Name	VerifyDocument
Beschreibung	Diese Operation verifiziert die Signatur eines Dokumentes. Der Basis-Consumer MUSS jede konform zur ClientsystemschnittstelleSignDocument erzeugte Signatur durch VerifyDocument prüfen können. Das Ergebnis der Prüfung wird, wenn gefordert, in Form eines standardisierten Prüfberichts in einerVerificationReport-Struktur gemäß [OASIS-VR] zurückgeliefert.

Aufruf- parameter	
SIG: OptionalInputs	Enthält optionale Eingabeparameter (angelehnt an dss:OptionalInputs gemäß [OASIS-DSS] Section 2.7): Die zulässigen optionalen Eingabeparameter sind unten erläutert.
SIG: Document	Enthält im Fall der Prüfung von detached oder enveloped Signaturen das zur Signatur gehörende bzw. das diese umschließende Dokument (siehe [OASIS-DSS] Section 2.4.2 und oben).
dss: SignatureObject	Enthält die zu prüfende Signatur, wenn sie nicht im Dokument selbst eingebettet ist ([OASIS-DSS] Kapitel 4.1). Die Signatur wird in ss:Base64Signature mit entsprechendem gesetztemType-Attribut (siehe signatureType) übergeben, wobei der nachfolgende Werte unterstützt werden muss: • CMS-Signatur urn:ietf:rfc:5652
	
SIG: VerifyManifests	Dieses Element wird durch den Basis-Consumer nicht verwendet.

					
SIG: UseVerification Time	Durch das in [OASIS-DSS] (Abschnitt 4.5.2) spezifizierte Element kann die Prüfung der Signatur bezüglich eines durch den Aufrufer bestimmten Zeitpunktes (Benutzerdefinierter_Zeitpunkt) erfolgen.				
dss: AdditionalKeyInfo	Dieses Element wird durch den Basis-Consumer nicht verwendet.				
vr: Return VerificationReport	Durch dieses in [OASIS-VR] spezifizierte Element kann die Erstellung eines ausführlichen Prüfberichtes angefordert werden.				
dss:Schemas	Dieses Element wird durch den Basis-Consumer nicht verwendet.				
Rückgabe	<table border="1" data-bbox="411 1574 1380 1951"> <tr> <td data-bbox="411 1574 603 1630">Status</td><td data-bbox="603 1574 1380 1630">Enthält den Ausführungsstatus der Operation.</td></tr> <tr> <td data-bbox="411 1630 603 1951">SIG: Verifi cation Result</td><td data-bbox="603 1630 1380 1951">  Das Element SIG:VerificationResult enthält das </td></tr> </table>	Status	Enthält den Ausführungsstatus der Operation.	SIG: Verifi cation Result	 Das Element SIG:VerificationResult enthält das
Status	Enthält den Ausführungsstatus der Operation.				
SIG: Verifi cation Result	 Das Element SIG:VerificationResult enthält das				

		Ergebnis der Prüfung als Ampel, den Typ des zugehörigen angenommenen Signaturzeitpunkts und der angenommene Signaturzeitpunkt selbst.
SIG: High Level Result		Das Ergebnis der Prüfung (Ampelschaltung) mit folgenden Werten: • VALID: alle Signaturen sind gültig • INVALID: mindestens eine der Signaturen ist ungültig • INCONCLUSIVE: in allen anderen Fällen
SIG: Time stamp Type		Der Typ des angenommenen Signaturzeitpunkts mit folgenden Werten: • SIGNATURE_EMBEDDED_TIMESTAMP: in der Signatur eingebetter Zeitpunkt Ermittelter_Signaturzeitpunkt_Eingebettet • SYSTEM_TIMESTAMP: Systemzeit des Consumers bei Signaturprüfung Ermittelter_Signaturzeitpunkt_System • USER_DEFINED_TIMESTAMP: benutzerdefinierter Zeitpunkt Benutzerdefinierter_Zeitpunkt Als Format darf jedes zum XML-Typ "dateTime" konforme Format verwendet werden (<element name="Timestamp" type="dateTime"/>). Wenn mehrere Signaturen im Dokument vorhanden sind, wird hier der angenommene Signaturzeitpunkt der jüngsten Signatur angegeben.
SIG: Timestamp		Im Element SIG:Timestamp wird der zu SIG:TimestampType gehörende Zeitstempel zurückgegeben.
SIG: Optional Outputs		Enthält (angelehnt an dss:OptionalOutputs, wie in Abschnitt 2.7 von [OASIS-DSS] beschrieben) optionale Ausgangselemente: 
dss: Verify Manifest Results		Dieses Element wird durch den Basis-Consumer nicht verwendet.
vr: Verificatio n Report		Dieses in [OASIS-VR] spezifizierte Element wird zurückgeliefert, falls dasReturnVerificationReport-Element als Eingabeparameter verwendet wurde.

Vorbedingungen	Keine
Nachbedingungen	Keine

SigningTime ist der zu prüfende Signaturzeitpunkt. Dieser ergibt sich wie folgt:

1. SigningTime= Benutzerdefinierter_Zeitpunkt, wenn SIG:UseVerificationTime Angaben enthält, sonst
2. SigningTime= Ermittelter_Signaturzeitpunkt_Eingebettet wenn die Signatur einen Signaturzeitpunkt enthält, sonst
3. SigningTime= Ermittelter_Signaturzeitpunkt_System, die Systemzeit.

Das Verifizieren erfolgt durch Aufruf von PL_TUC_VERIFY_DOCUMENT_nonQES {

```

SIGNED_DOCUMENT =SIG:Document;
CERTIFICATE = extrahiert ausSIG:Document;
SIGNATURE =dss: SignatureObject ;
TIME_REFERENCE = SigningTime;
}.

```

[<=]

6.2.2.4 ExternalAuthenticate

A_17578-04 -Basis-Consumer, Operation ExternalAuthenticate

Der Signaturdienst des Basis-Consumer MUSS an der Client-Systemschnittstelle die Operation ExternalAuthenticate wie in Tabelle Tab_Operation_ExternalAuthenticate beschrieben anbieten.

Tabelle 16: Tab_Operation_ExternalAuthenticate

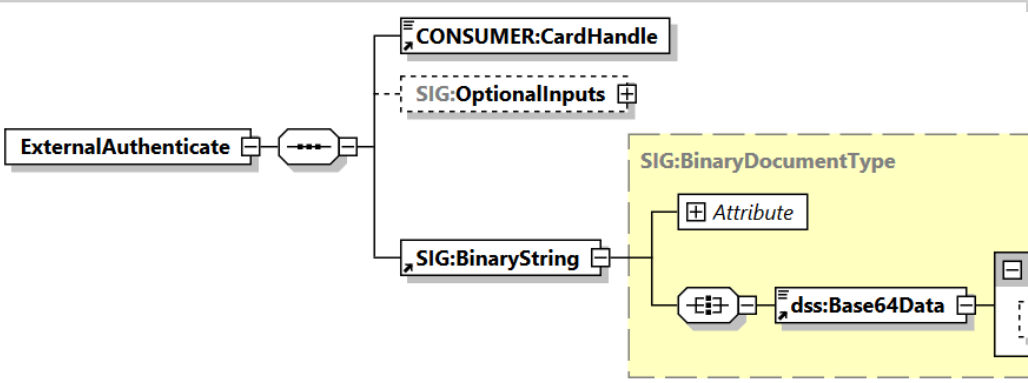
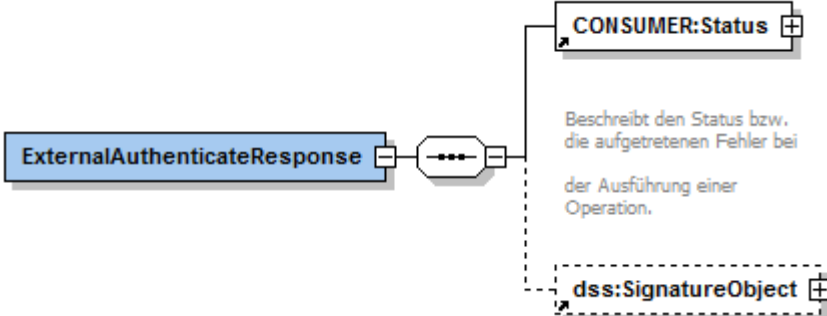
Name	ExternalAuthenticate	
Beschreibung	Diese Operation versieht einen Binärstring der maximalen Länge 256 Bit mit einer nicht-qualifizierten elektronischen Signatur (nonQES). Dazu wird das Signaturverfahren ECDSA verwendet.	
Aufrufparameter		
	Name	Beschreibung
	CONSUMER: CardHandle	Identifiziert die zu verwendende Signaturquelle. Die Operation unterstützt nur Identitäten gem. Hinweis unter

		Tabelle 7 Tab_Personalisierung_HSM.
	SIG: Binary String	Dieses Element enthält im Kindelement <code>dss:Base64Data</code> den zu signierenden Binärstring. Das XML Attribut <code>SIG:BinaryString/dss:Base64Data/@MimeType</code> den Wert "application/octet-stream" haben. Die maximale Länge des Binärstrings beträgt 256 Bit entsprechend der maximal zu erwartenden Hash-Größe. Als Signaturverfahren wird ausschließlich ECDSA unterstützt. Für die Signaturerstellung gilt: Es erfolgt die Signaturerstellung gemäß [BSI-TR-03111]#4.2.1. Als Eingangsparameter wird der Hash vom Aufrufer in SIG: BinaryString übergeben.
Rückgabe		
	CONSUMER: Status	Enthält den Status der ausgeführten Operation.
	dss: Signature Object	Enthält im Erfolgsfall die erzeugte Signatur in Form eines <code>dss:SignatureObject</code>-Elements gemäß [OASIS-DSS] (Abschnitt 3.2). Der Signaturwert wird im XML-Element <code>dss:SignatureObject/dss:Base64Signature</code> übergeben. Das XML-Attribut <code>dss:SignatureObject/dss:Base64Signature/@Type</code> kennzeichnet durch den Wert: urn:bsi:tr:03111:ecdsa den Signatur-Typ ECDSA. Die XML-Elemente <code>dss:SignatureObject/ds:Signature</code>, <code>dss:SignatureObject/dss:Timestamp</code>, <code>dss:SignatureObject/dss:SignaturePtr</code> und <code>dss:SignatureObject/dss:Other</code> werden nicht verwendet.
Vorbedin g	Keine	

ungen	
Nachbedingungen	Keine

Der Ablauf der Operation ExternalAuthenticate ist in Tabelle Tab_Ablauf_ExternalAuthenticate beschrieben:

Tabelle 17: Tab_Ablauf_ExternalAuthenticate

Nr.	Aufruf Technischer Use Case oder Interne Operation	Beschreibung
1.	checkArguments	Alle übergebenen Parameterwerte werden auf Konsistenz und Gültigkeit überprüft. Treten hierbei Fehler auf, so bricht die Operation mit Fehler 4000 ab.
2.	Signiere	Das Signieren erfolgt durch Aufruf von PL_TUC_SIGN_HASH_nonQES { IDENTIFIKATOR = CardHandle; SIGNATURVERFAHREN = ECDSA mit SHA-256; HASHWERT = SIG:BinaryString; } Tritt hierbei ein Fehler auf, so bricht die Operation mit Fehler 4123 ab.

Tabelle 18: Tab_Fehler_ExternalAuthenticate

Fehlercode	ErrorType	Severity	Fehlertext
Neben den Fehlercodes der aufgerufenen TUCs können folgende weitere Fehlercodes auftreten:			
4000	Technical	Error	Syntaxfehler
4123	Technical	Error	Fehler bei Signaturerstellung

Der zulässige private Schlüssel für die Nutzung durch die Operation ExternalAuthenticate ist für SM-B PrK.HCI.AUT in DF.ESIGN.
[<=]

6.3 Zertifikatsdienst

6.3.1 Durch Module nutzbare TUCs

A_17401 -Systemprozess PL_TUC_PKI_VERIFY_CERTIFICATE

Der Basis-Consumer MUSS den Systemprozess PL_TUC_PKI_VERIFY_CERTIFICATE implementieren und bereitstellen.[<=]

6.3.2 Operationen an der Clientsystemschnittstelle

A_17408 -Basisdienst Zertifikatsdienst

Der Basis-Consumer MUSS Clientsystemen einen Basisdienst Zertifikatsdienst zur Verfügung stellen.

Tabelle 19: Tab_Zertifikatsdienst

Name	CertificateService	
Version	Siehe Anhang B	
Namensraum	Siehe Anhang B	
Namensraum-Kürzel	CERT für Schema und CERTW für WSDL	
Operationen	Name	Kurzbeschreibung
	VerifyCertificate	Prüfung des Status eines Zertifikats
WSDL	CertificateService.wsdl	
Schema	CertificateService.xsd	

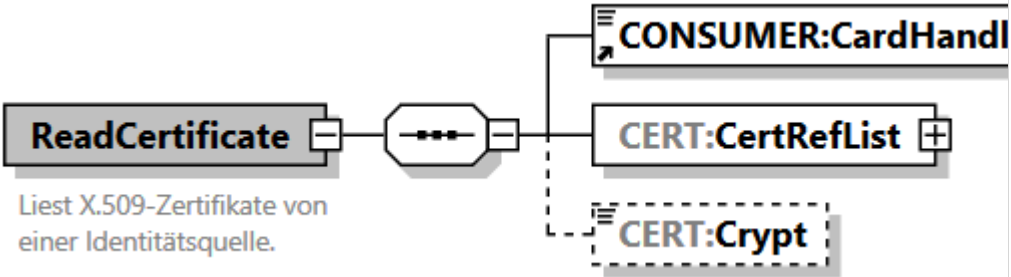
[<=]

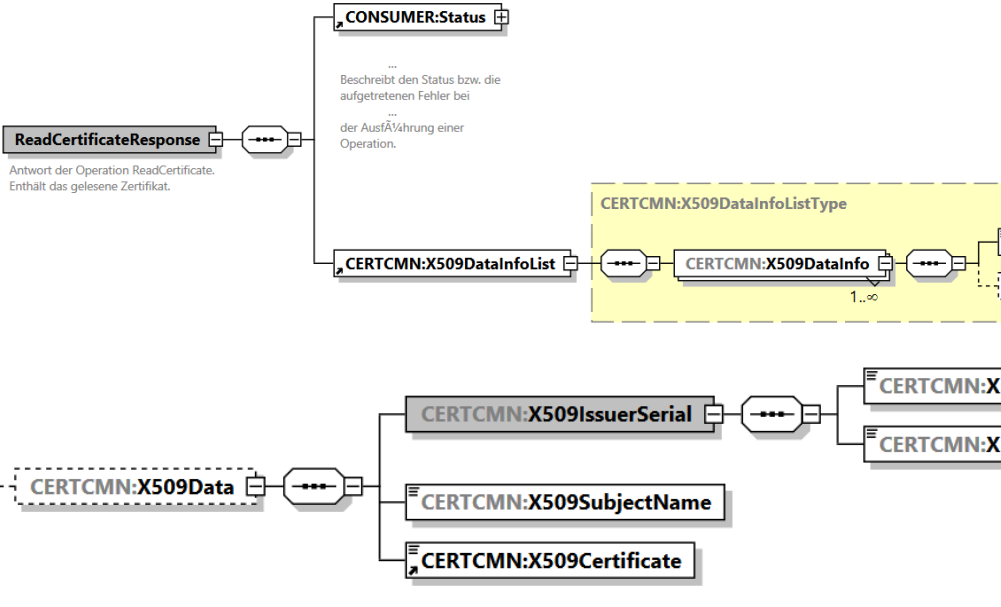
6.3.2.1 ReadCertificate

A_24782-02 -Basis-Consumer, Operation ReadCertificate

Die Basisanwendung Zertifikatsdienst des Basis-Consumer MUSS an der Client-Schnittstelle eine Operation ReadCertificate wie in Tabelle Tab_Operation_ReadCertificate beschrieben anbieten.

Tabelle 20: Tab_Operation_ReadCertificate

Name	ReadCertificate
Beschreibung	Liest X.509-Zertifikate von einem Identitätsträger.
Aufrufparameter	 <pre> sequenceDiagram participant CONSUMER as CONSUMER:CardHandl participant CERT as CERT:CertRefList participant CERT_CRYPT as CERT:Crypt CONSUMER->>CERT: ReadCertificate Note over CERT: Liest X.509-Zertifikate von einer Identitätsquelle. CERT-->>CERT_CRYPT: </pre>

	Name	Beschreibung
	CardHandle	Gibt die Quelle an, von der das Zertifikat gelesen werden soll. Die Operation unterstützt nur Identitäten gem. Hinweis unter Tabelle 7 Tab_Personalisierung_HSM. Die Operation ReadCertificate DARF das Lesen von Zertifikaten der eGK oder HBAX (HBA, HBA-VK)NICHT unterstützen.
	CertRefList	Gibt an, welche(s) Zertifikat(e) gelesen werden soll. Mögliche Werte für CertRef sind: • C.AUT • C.OSIG
	Crypt	Optional; Default: ECC Gibt den kryptographischen Algorithmus vor, für den das Zertifikat ermittelt werden soll. Wertebereich: RSA, ECC • RSA: Zertifikat für RSA-2048 • ECC: Zertifikat für ECC-256
Rückgabe		 The diagram illustrates the structure of the ReadCertificateResponse message. It consists of a CONSUMER:Status field and a CERTCMN:X509DataInfoList field. The CONSUMER:Status field is described as: "Beschreibt den Status bzw. die aufgetretenen Fehler bei ... der Ausführung einer Operation." The CERTCMN:X509DataInfoList field is a list of CERTCMN:X509DataInfo objects, with a cardinality of 1..∞. Each CERTCMN:X509DataInfo object contains a CERTCMN:X509Data field (dashed box) and a CERTCMN:X509Certificate field. The CERTCMN:X509Data field is further detailed with a CERTCMN:X509IssuerSerial field (containing CERTCMN:X509IssuerSerial and CERTCMN:X509SubjectName) and a CERTCMN:X509Certificate field.
	Status	Enthält den Ausführungsstatus der Operation.
	CertRef	Dieses Element beinhaltet die Referenz des Zertifikats, welches bei der Anfrage übergeben wurde.

	X509Data	Inhalt des über die CertRef referenzierten Zertifikats. Ist das referenzierte Zertifikat nicht vorhanden, so wird dieses Element nicht vom Konnektor gefüllt.	
		X509Issuer Name	Enthält den Issuer-Name des Zertifikats. Bezüglich des Encodings sind die in [XMLDSig#4.4.4.4.1] angegebenen Regeln zu beachten (Escaping von Sonderzeichen etc.)
		X509Serial Number	Enthält die serialNumber des Zertifikats.
		X509Subject Name	Enthält das Feld subject.CommonName. Bezüglich des Encodings sind die in [XMLDSig#4.4.4.4.1] angegebenen Regeln zu beachten (Escaping von Sonderzeichen etc.)
		X509 Certificate	Enthält das base64-codierte Zertifikat, dessen Binärstruktur wiederum ASN.1-codiert (gemäß [COMMON_PKI]) vorliegt.
Vorbedingungen	Keine		
Nachbedingungen	Keine		

Der Ablauf der Operation ReadCertificate ist in Tabelle Tab_Ablauf_ReadCertificate beschrieben:

Tabelle 21: Tab_Ablauf_ReadCertificate

Nr.	Aufruf Technischer Use Case oder Interne	Beschreibung
-----	--	--------------

	Operation	
1.	checkArguments	Die übergebenen Werte werden auf Konsistenz und Gültigkeit überprüft. Treten hierbei Fehler auf, so bricht die Operation mit Fehler 4000 ab. Wurdeim CardHandle eine eGK oder HBAx (HBA, HBA-VK) übergeben, wird Fehlercode 4090 zurückgeliefert.
2.	getEF	Für jedes Paar von CertRef und CardHandle wird in Abhängigkeit des Parameters Crypt gemäß TabelleTab_IdentityObjekte_ReadCertificate das zu lesende File (EF) bestimmt: Ist die übergebene Zertifikatsreferenz ungültig, wird Fehlercode 4149 zurückgegeben. Das Lesen von Zertifikaten der eGK oder HBAx (HBA, HBA-VK) ist aus Sicherheitsgründen für Clientsysteme nicht zulässig.
3.	Lese Zertifikate	Für jedes Paar von CardHandle und EF wird nun das Zertifikat vom Identitätsträger (HSM) ausgelesen. Falls das File (EF) nicht vorhanden ist, wird die Operation abgebrochen und Fehler 4258 zurückgegeben. Das Zertifikat KANN vom Consumer gecached werden, sofern sichergestellt wird, dass der Cache invalidiert wird, sobald sich die Identität des gecachten Zertifikats auf dem Identitätsträger (HSM) ändert. Das Zertifikat KANN vom Consumer von einer auf dem lokalen und nur durch die Consumer Instanz zugänglichen Filesystem abgelegten Kopie zurückgegeben werden, sofern sichergestellt ist, dass diese Kopie zu jederzeit identisch mit dem Zertifikat auf dem Identitätsträger gehalten wird, sobald sich die Identität auf dem Identitätsträger (HSM) ändert.
4.	Zertifikatsattribute extrahieren	Aus jedem Zertifikat werden die zu liefernden Attribute extrahiert. Die Ergebnisstruktur wird mit den erhaltenen Rückgabewerten gefüllt.

Tabelle 22: Tab_Fehler_ReadCertificate

Fehlercode	ErrorType	Severity	Fehlertext
Neben den Fehlercodes der aufgerufenen technischen Use Cases können folgende weitere Fehlercodes auftreten:			
4000	Technical	Error	Syntaxfehler

4149	Technical	Error	Ungültige Zertifikatsreferenz
4090	Security	Error	Zugriff auf Identität nicht gestattet
4258	Technical	Error	Zertifikate nicht vorhanden auf Identität: <CardHandle>

Das konkrete Zertifikatsobjekt eines Identitätsträgers ist abhängig vom Typ und dem gewählten kryptographischen Verfahren. Die folgende Tabelle führt auf, welche Zertifikatsobjekte eines Identitätsträgers in Abhängigkeit vom kryptographischen Verfahren für die jeweilige Zertifikatsreferenz ausgewählt werden.

Tabelle 23: Tab_IdentityObjekte_ReadCertificateKartenobjekt in Abhängigkeit vom kryptographischen Verfahren

Identität	CertRef (Wert)	Objekt der Karte (in DF.ESIGN)	
		Crypt== RSA	Crypt== ECC
SM-B (KTR/Org)	C.AUT	EF.C.HCI.AUT	EF.C.HCI.AUT.E256
	C.OSIG	EF.C.HCI.OSIG.R2048	EF.C.HCI.OSIG.E256

Hinweis:

- Beim Aufrufparameter CertRefList gibt es zwar nur eine Auswahlmöglichkeit, aber dies sorgt für zukünftige Erweiterbarkeit analog zur äquivalenten Schnittstelle ReadCardCertificate, definiert in [gemSpec_Kon].

[<=]

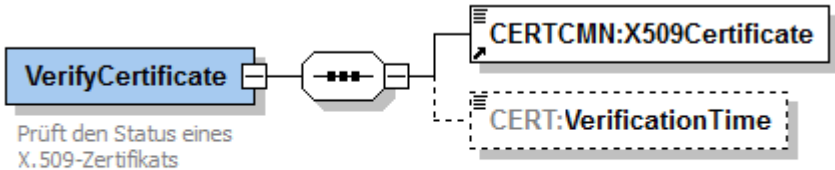
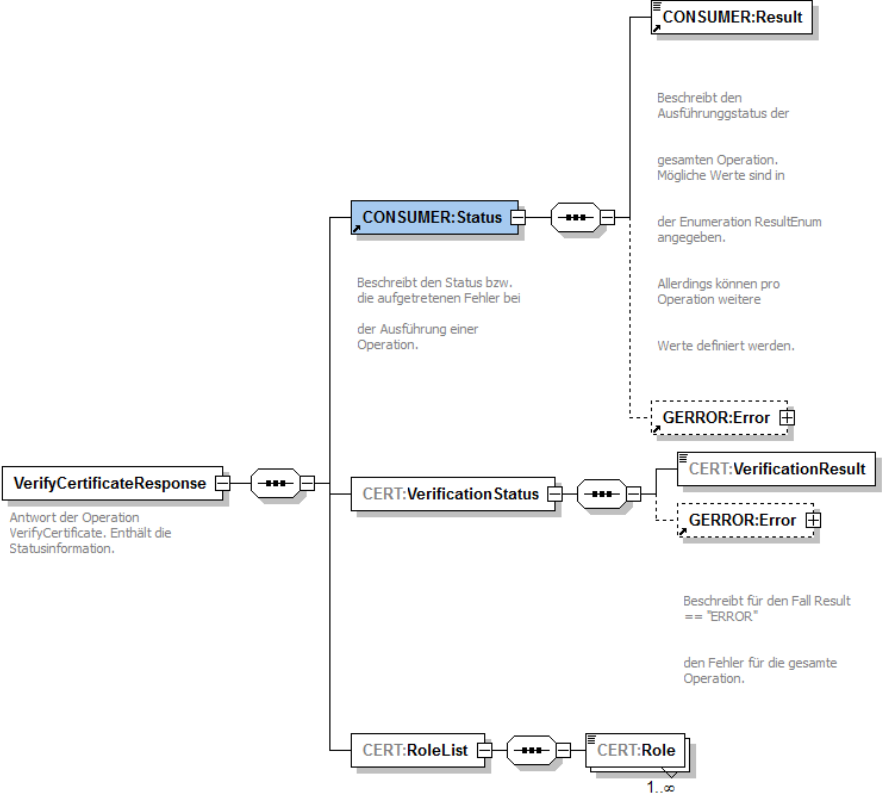
6.3.2.2 VerifyCertificate

A_17429-02 -Basis-Consumer, Operation VerifyCertificate

Der Zertifikatsdienst des Basis-Consumer MUSS an der Clientsystemschnittstelle eine Operation VerifyCertificate wie in Tabelle Tab_Operation_VerifyCertificate beschrieben anbieten.

Tabelle 24: Tab_Operation_VerifyCertificate

Name	VerifyCertificate
Beschreibung	Prüft den Status eines Zertifikats.

Aufruf- parameter		
	Name	Beschreibung
	CERTCMN: X509Certificate	Enthält das base64-codierte Zertifikat, dessen Binärstruktur wiederum ASN.1-codiert (gemäß [gemSpec_PKI]) vorliegt.
	CERT: VerificationTime	Der für die Prüfung zu verwendende Referenzzeitpunkt. Falls der Parameter nicht angegeben ist, wird als Referenzzeitpunkt die Systemzeit verwendet.
Rückgabe		
	Status	Enthält den Ausführungsstatus der Operation.
	CERT:VerificationStatus	Enthält eines der drei möglichen Prüfungsergebnisse in

		CERT:VerificationResult • VALID • INCONCLUSIVE • INVALID sowie weiter Details zu den Zuständen „INCONCLUSIVE“ und „INVALID“ in GERROR:Error.
	CERT:RoleList	OIDs der im Zertifikat gespeicherten Rollen.
Vorbedingungen	Keine	
Nachbedingungen	Keine	

Der Ablauf der Operation VerifyCertificate ist in Tabelle Tab_Ablauf_VerifyCertificate beschrieben:

Tabelle 25: Tab_Ablauf_VerifyCertificate

Nr.	Aufruf Technischer Use Case oder Interne Operation	Beschreibung
1.	PL_TUC_PKI_VERIFY_CERTIFICATE	Die Zertifikatsprüfung erfolgt durch Aufruf von PL_TUC_PKI_VERIFY_CERTIFICATE { Zu prüfendes Zertifikat = CERTCMN:X509Certificate; Referenzzeitpunkt = CERT:VerificationTime; PolicyList = keine Einschränkung; KeyUsage = empty; ExtendedKeyUsage = empty; OCSP-Graceperiod = empty; Offline-Modus = nein; OCSP-Response = empty ; Timeout = empty; TOLERATE_OCSP_FAILURE = ja; }
2.		Wenn der Prüfprozess fehlerhaft war und nicht zu einem Ergebnis im Sinne eines VerificationResult führt, wird eine FaultMessage erzeugt. War der Prüfprozess erfolgreich, wird eine VerifyCertificateResponse mit • CONSUMER:Status/CONSUMER:Result=OK, • dem VerificationStatus (als Ergebnis der Zertifikatsprüfung) und • den ermittelten Rollen-OIDs erzeugt.

		Ein Prüfergebnis „INCONCLUSIVE“ bzw. „INVALID“ wird in CERT:VerificationStatus/GERROR:Error mit den zugehörigen Fehlermeldungen detailliert (in diesem Fall kann CONSUMER:Status/CONSUMER:Result=OK oder CONSUMER:Status/CONSUMER:Result=Warning gesetzt sein).
--	--	---

Tabelle 26: Tab_Übersicht_VerificationResult_VerifyCertificate

CERT:VerificationResult	Bedeutung
VALID	Wenn Gültigkeit zu Referenzzeitpunkt: "gültig" Mathematische Gültigkeit:"gültig" OCSP-Prüfung: Online gültig
INVALID	Wenn mindestens ein Wert von (Gültigkeit zu Referenzzeitpunkt, Mathematische Gültigkeit, OCSP-Prüfung) „ungültig“, „Prüffehler“ oder „gesperrt“ ist.
INCONCLUSIVE	Wenn OCSP-Prüfung „unbekannt“ und die andere Werte „gültig“ sind.

[<=]

6.4 LDAP-Proxy

6.4.1 Durch Module nutzbare TUCs

A_17343 -Basis-Consumer, LDAPv3 Operationen für interne Module

Der Basis-Consumer MUSS für die in Tab_Ldap_TUC_Mapping aufgelisteten Systemprozesse die entsprechenden LDAP-Operationen implementieren und zur Nutzung durch interne Module zur Verfügung stellen.

Tabelle 27: Tab_Ldap_TUC_Mapping

LDAPv3-Operation	Systemprozess
Bind	PL_TUC_VZD_BIND
Unbind	PL_TUC_VZD_UNBIND
Search	PL_TUC_VZD_SEARCH
Abandon	PL_TUC_VZD_ABANDON

[<=]

6.4.2 Unterstützte LDAPv3-Operationen an der Clientsystemschnittstelle

A_17341-01 -Basis-Consumer, LDAPv3-Operationen an der Clientsystemschnittstelle

Der Basis-Consumer MUSS an der Clientsystemschnittstelle die folgenden LDAPv3-Operationen für den Zugriff auf den Verzeichnisdienst der TI gemäß [RFC4511] anbieten.

- Bind Operation
- Unbind Operation
- Search Operation
- Abandon Operation

Andere LDAPv3-Operationen MÜSSEN mit dem LDAP-Fehler unwillingToPerform (53) beantwortet werden.

Fehler MÜSSEN gemäß [RFC4511]#Appendix A behandelt werden.【<=】

6.5 Clientmodul KOM-LE

6.5.1 Allgemeine Anforderungen

A_17298 -Synchronisation mit der Systemzeit der zentralen TI-Plattform

Das KOM-LE-Clientmodul MUSS sich unter Verwendung des Systemprozesses PL_TUC_NET_SYNC_TIME mit der Systemzeit des Zeitserver der zentralen TI-Plattform synchronisieren.【<=】

A_17299-02 -Konfigurationsparameter

Das KOM-LE-Clientmodul MUSS die in Tabelle [gemSpec_CM_KOMLE#Tab_Konf_Param] aufgelisteten Parameter, bis auf die Parameter TLS_AUTH_KONNEKTOR, KONNEKTOR_TIMEOUT und KONNEKTOR_URI, über eine Managementoberfläche oder eine Konfigurationsdatei konfigurierbar gestalten und mit einer Standardkonfiguration entsprechend den Defaultwerten ausliefern.【<=】

A_22664 -Basis-Consumer - Prüfung der verwendeten Clientmodul-Version beim Senden

Das KIM-Clientmodul des Basis-Consumers MUSS vor dem Versenden einer Nachricht die KIM-Version des Absenders mittels des LDAP-Directory Attributs:komLeData aus dem Verzeichnisdienst [gemSpec_VZD#5] abfragen. Ist die KIM-Version des Clientmoduls kleiner als die im Verzeichnisdienst eingetragene, so MUSS das Clientmodul den Absender mit einer E-Mail darüber informieren. Aus dem Inhalt der E-Mail MUSS hervorgehen, dass die verwendete Clientmodul-Version veraltet ist. Die E-Mail ist weder zu signieren noch zu verschlüsseln und entspricht der Delivery Status Notification gemäß [RFC3461-3464]. Ist die KIM-Version des Clientmoduls größer als die im Verzeichnisdienst abgefragte Version KANN das Clientmodul des Basis-Consumers das LDAP-Directory Attribut:komLeData für den Absender mit der neuen Version überschreiben.【<=】

A_26447-01 -ECC-preferred-Funktionalität ein- und ausschaltbar

Der Consumer MUSS die ECC-preferred-Funktionalität, wie sie in den Anforderungen TIP1-A_6984-*, A_17525-* und KOM-LE-A_2022-* gefordert wird, ein- und ausschaltbar gestalten. Welche Anforderungen dabei in welchem Zustand vom Consumer funktional aktiv bereitgestellt werden müssen und welche nicht, ist in Tabelle "Tab_ECC-preferred-Funktionalität" festgelegt.

Tabelle 28: Tab_ECC-preferred-Funktionalität

Anforderung	Zustand "ECC-preferred-Funktionalität eingeschaltet"	Zustand: "ECC-preferred-Funktionalität ausgeschaltet" (Default-Zustand)
TIP1-A_6984-03	MUSS funktional aktiv sein	DARF NICHT funktional aktiv sein
A_17525-04	MUSS funktional aktiv sein	DARF NICHT funktional aktiv sein
KOM-LE-A_2022-01	MUSS funktional aktiv sein	DARF NICHT funktional aktiv sein
A_17578-04	MUSS funktional aktiv sein	DARF NICHT funktional aktiv sein
TIP1-A_6984-02	DARF NICHT funktional aktiv sein	MUSS funktional aktiv sein
A_17525-03	DARF NICHT funktional aktiv sein	MUSS funktional aktiv sein
KOM-LE-A_2022	DARF NICHT funktional aktiv sein	MUSS funktional aktiv sein
A_17578-03	DARF NICHT funktional aktiv sein	MUSS funktional aktiv sein

Im Default-Zustand MUSS die ECC-preferred-Funktionalität ausgeschaltet sein.【<=】

A_26448 -Ein- und Ausschalten der ECC-preferred-Funktionalität

Der Anbieter des Consumers MUSS die ECC-preferred-Funktionalität, wie sie in der Anforderung A_26447-* definiert wird, jederzeit auf Weisung der gematik über einen abgesicherten Prozess für alle bei ihm in Betrieb befindlichen Instanzen ein- und ausschalten können.【<=】

Es steht dem Hersteller des Consumers frei, wie die Schalter aus A_26447-* umgesetzt werden. Beispielsweise sind die Realisierung über eine Konfigurationsdatei oder auch ein zur Laufzeit der Consumer-Instanz schaltbare Konfiguration über Management-UI möglich. Weiterhin sei auch vermerkt, dass zum Umschalten der Zustände gem. A_26448-* Consumer-Instanzen neu gestartet werden dürfen.

6.5.1.1 Eingeschaltete ECC-preferred-Funktionalität

Um die Umschaltung der ECC-preferred-Funktionalität gemäß A_26447-* und A_26448-* umsetzen zu können, werden Anforderungen benötigt, die die ECC-preferred-Funktionalität im eingeschalteten Zustand definieren.

In diesem Kapitel werden Anforderungen aufgelistet, die sonst in keinen anderen Dokumenten zu finden sind.

KOM-LE-A_2022-01 -Verschlüsseln der Nachricht mit den Verschlüsselungszertifikaten C.HCI.ENC bzw. C.HP.ENC

Das Clientmodul MUSS vom Clientsystem erhaltene E-Mail-Nachrichten sowohl für jeden in den RCPT-Kommandos angegebenen Empfänger als auch für den Sender aus dem from bzw. sender Header-Element der Nachricht mit Verschlüsselungszertifikaten (C.HCI.ENC für eine Institution oder C.HP.ENC für einen Leistungserbringer) verschlüsseln.

Falls dem Sender bzw. Empfänger sowohl ein ECC- als auch RSA-Zertifikat zugeordnet ist, MUSS für die Verschlüsselung ausschließlich das ECC-Zertifikat verwendet werden. In diesem Fall DARF das RSA-Zertifikat NICHT verwendet werden.

[<=]

Hinweis: Für die SMC-B-Zertifikate einiger Herausgeber gibt es kein eindeutiges Merkmal, an dem die Zugehörigkeit zweier Zertifikate zu ein und derselben SMC-B erkennbar ist. In solchen Fällen ist es zulässig, diese Zugehörigkeit anhand bestimmter Indizien im Zertifikat mit einer gewissen statistischen Sicherheit festzustellen. Ein Algorithmus zum Herausfiltern von RSA-Empfängerzertifikaten, welcher eine statistisch ausreichende Sicherheit gewährleistet, ist unter <https://github.com/gematik/kim-examples/releases/tag/1.0.0> zu finden.

6.5.1.2 Ausgeschaltete ECC-preferred-Funktionalität

Um die Umschaltung der ECC-preferred-Funktionalität gemäß A_26447-* und A_26448-* umsetzen zu können, werden Anforderungen benötigt, die die ECC-preferred-Funktionalität im ausgeschalteten Zustand definieren.

In diesem Kapitel werden diese Anforderungen für bessere Lesbarkeit aufgelistet, auch wenn sie sonst in anderen Dokumenten zu finden sind.

KOM-LE-A_2022 -Verschlüsseln der Nachricht mit den Verschlüsselungszertifikaten C.HCI.ENC bzw. C.HP.ENC

Das Clientmodul MUSS vom Clientsystem erhaltene E-Mail-Nachrichten sowohl für jeden in den RCPT-Kommandos angegebenen Empfänger als auch für den Sender aus dem from bzw. sender Header-Element der Nachricht mit allen dem Sender bzw. Empfängern zugeordneten Verschlüsselungszertifikaten (C.HCI.ENC für eine Institution oder C.HP.ENC für einen Leistungserbringer) verschlüsseln.

[<=]

TIP1-A_6984-02 -Ablauf der hybriden Verschlüsselung eines Dokuments

Produkttypen und Dienste der TI, die eine Plattformleistung PL_TUC_HYBRID_ENCRYPT umsetzen, MÜSSEN die Schritte zum Verschlüsseln eines gegebenen Dokuments in der angegebenen Reihenfolge durchführen:

	Teilschritt der hybriden Verschlüsselung	Teilergebnis
1	Erzeugung eines symmetrischen Schlüssels gemäß BSI-TR-03116-1#3.5 Schlüsselerzeugung] und den Festlegungen in [gemSpec_Krypt#3.5.1 Hybride Verschlüsselung] -> S_{symm}	Symmetrischer Schlüssel Falls Symmetrischer Schlüssel nicht erzeugt werden kann => Fehler
2	Dokument Doc mit symmetrischem Schlüssel S_{symm} verschlüsseln -> Doc_{enc} Falls Doc ein XML-Dokument/Fragment ist: XMLEnc: Es MÜSSEN die Vorgaben aus [gemSpec_Krypt#3.1.4] beachtet werden. Sonst: CMS Es MÜSSEN die Vorgaben aus [gemSpec_Krypt#3.5.1] beachtet werden.	symmetrisch verschlüsseltes Dokument
3	Für jedes Empfängerzertifikat $\text{Cert}(i)$ Schlüssel S_{symm} mit öffentlichem Schlüssel S_{public} der	pro Empfängerzertifikat:

	Empfängeridentität (liegt in Zertifikat Cert(i)) gemäß Vorgaben aus gemSpec_Krypt#3.1.5] (XML, RSA) bzw. [gemSpec_Krypt#3.5.2] (CMS, RSA) oder gemäß Vorgaben aus [gemSpec_Krypt#5.7] (XML/CMS, ECC) verschlüsseln -> $(S_{\text{symm}})_{\text{enc}(i)}$	mit öffentlichem Schlüssel der Empfängeridentität verschlüsselter symmetrischer Schlüssel
4a	XMLEnc: Alle verschlüsselten Dokumentenschlüssel $\{(S_{\text{symm}})_{\text{enc}(i)}\}$ als EncryptedKey und mit dem verschlüsselten Dokument Doc_{enc} zu einem EncryptedData-Element gemäß [XML-Enc 1.1] zusammenfügen: Doc_{enc} + $\{(S_{\text{symm}})_{\text{enc}(i)}\}$ + Attribute -> D Pro Empfängerzertifikat wird ein Element EncryptedKey/KeyInfo/X509Data/X509Certificate base64-kodiert und darin DER-kodiert abgelegt.	zusammengefügt XML-ENC-EncryptedData-Element
4b	CMS: Alle verschlüsselten Dokumentenschlüssel $\{(S_{\text{symm}})_{\text{enc}(i)}\}$ und das verschlüsselte Dokument sind in einem Authenticated-Enveloped-Data Content Type gemäß [RFC-5083] und [RFC-5084] zusammenzuführen: Doc_{enc} + $\{(S_{\text{symm}})_{\text{enc}(i)}\}$ + Attribute -> D Bei Verschlüsselung des „content-encryption key“ wird „key transport“ verwendet Pro Empfängerzertifikat wird eine KeyTransRecipientInfo erzeugt, für RecipientIdentifier wird die Option IssuerAndSerialNumber verwendet ContentType = OID {... authEnvelopedData} = 1.2.840.113549.1.9.16.1.23	zusammengefügt CMS-Dokument
5	Rückmeldung an den Aufrufenden, entweder 1. OK + verschlüsseltes Dokument D oder 2. Fehler	

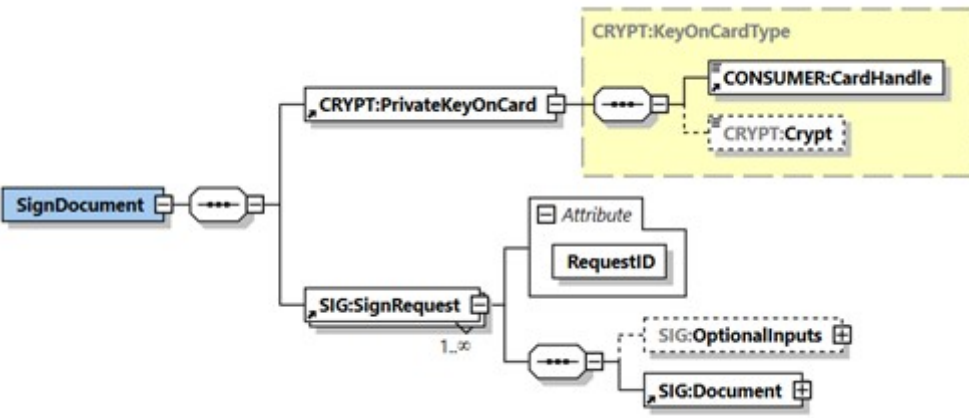
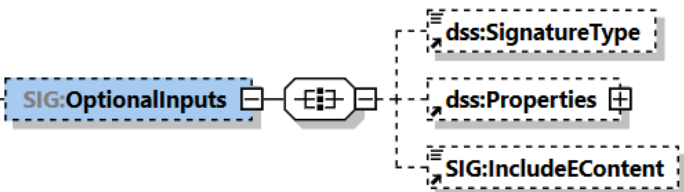
[<=]

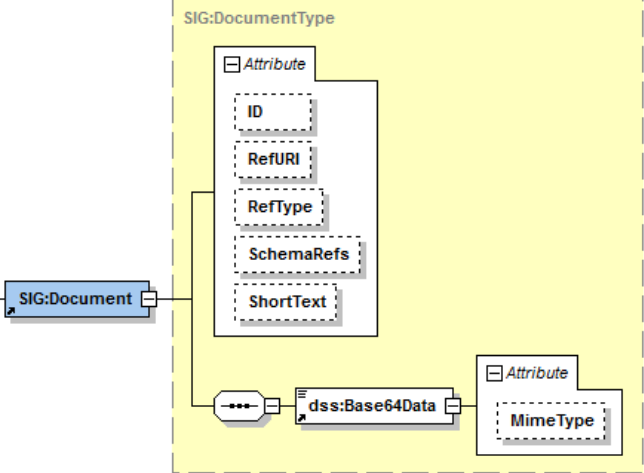
A_17525-03 -Basis- und KTR-Consumer, Operation SignDocument

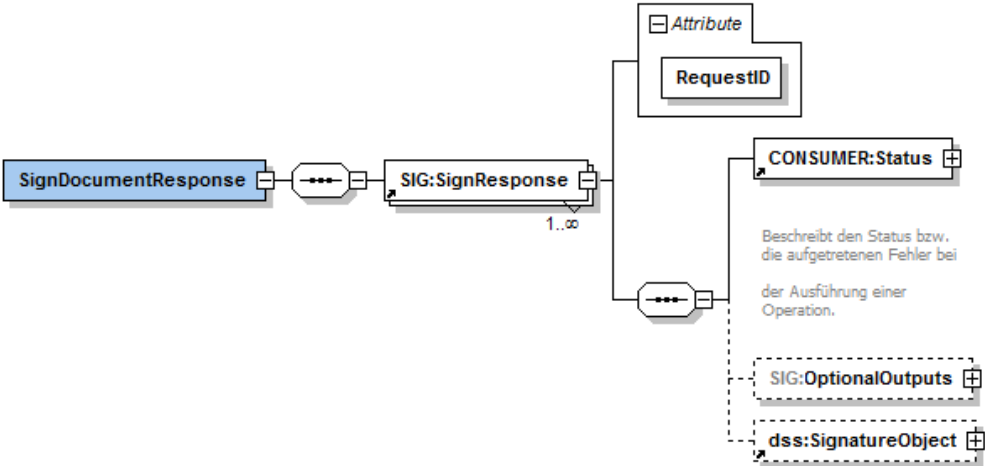
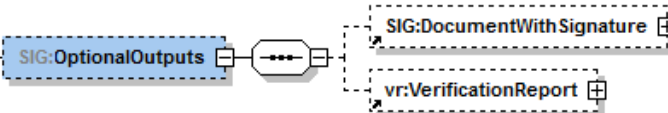
Der Signaturdienst des Basis- und KTR-Consumer MUSS an der Clientsystemschnittstelle eine an [OASIS-DSS] angelehnte Operation SignDocument wie in Tabelle Tab_Operation_SignDocument beschrieben anbieten.

Tabelle 29: Tab_Operation_SignDocument

Name	SignDocument
Beschreibung	Diese Operation lehnt sich an [OASIS-DSS] an. Sie enthält voneinander unabhängige SignRequests. Jeder SignRequest erzeugt eine Signatur für ein Dokument. Zur Signaturerzeugung werden Schlüssel und Zertifikate eines HSM benutzt. Es wird ausschließlich der Signatortyp "CMS-Signatur" gemäß

	[RFC 5652] (URIurn:ietf:rfc:5652) und das Profil CAdES-BES gemäß[CAdES] verwendet.	
Aufruf- parameter		
	PrivateKeyOnCard	Identifiziert die zu verwendende Karte mit dem (privaten) Schlüssel.
	CardHandle	Identifiziert die zu verwendende Signaturkarte.
	Crypt	Dieser Parameter steuert die Auswahl der Zertifikate und Schlüssel für die Signaturerstellung. Die Werte sind in der Tabelle Tab_Zertifikate_für_Sign/VerifyDocument vorgegeben. (Default-Wert ist RSA)
	SIG:SignRequest	EinSignRequestkapselt den Signaturauftrag für ein Dokument. Das verpflichtende XML-AttributRequestIDidentifiziert einenSignRequestinnerhalb eines Stapels vonSignRequestseindeutig. Es dient der Zuordnung derSignResponsezum jeweiligenSignRequest.
	SIG:OptionalInputs	Enthält optionale Eingangsparameter (angelehnt an dss:OptionalInputsgemäß [OASIS-DSS] Section 2.7): 

SIG:Document	 Dieses an das dss:DocumentElement aus [OASIS-DSS] Section 2.4.2 angelehnte Element enthält das zu signierende Dokument in dss:Base64Data.
dss:SignatureType	Durch dieses in [OASIS-DSS] (Abschnitt 3.5.1) beschriebene Element kann der generelle Typ der zu erzeugenden Signaturen angegeben werden. Es muss der Signatortyp CMS-Signatur (URI urn:ietf:rfc:5652) unterstützt werden. Fehlt dieses Element, so muss der Signatortyp CMS-Signatur (URI urn:ietf:rfc:5652) implizit verwendet werden.
dss:Properties	Durch dieses in [OASIS-DSS] (Abschnitt 3.5.5) definierte Element können zusätzliche signierte und unsignierte Eigenschaften (Properties) bzw. Attribute in die Signatur eingefügt werden. Es dürfen genau die folgenden Attribute ./SignedProperties/Property/Value/CMSAttribute - und ./UnsignedProperties/Property/Value/CMSAttribute enthalten sein. Ein solches XML-Element CMSAttribute muss ein vollständiges, base64/DER-kodiertes ASN.1-Attribute enthalten, definiert in [CMS#5.3.SignerInfo Type]. Es muss bei der Erstellung des CMS-Containers unverändert unter SignedAttributes bzw. UnsignedAttributes aufgenommen werden.
SIG:IncludeEContent	Durch dieses in [OASIS-DSS] (Abschnitt 3.5.7), definierte Element kann bei einer CMS-basierten Signatur das Einfügen des signierten Dokumentes in die Signatur angefordert werden. Fehlt dieses Element oder ist der Wert = "false",

		wird die Signaturvariante "detached" verwendet, ansonsten "enveloping".
Rückgabe		
	SIG:SignResponse	Eine SignResponse kapselt den ausgeführten Signaturauftrag pro Dokument. Die Zuordnung zwischen SignRequest und SignResponse erfolgt über die RequestID.
	CONSUMER:Status	Enthält den Status der ausgeführten Operation pro SignRequest.
	SIG:OptionalOutputs	Enthält optionale Ausgangsparameter. Dieses Element wird durch den Basis- und KTR-Consumer nicht befüllt.
		
	SIG:DocumentWithSignature	Dieses Element wird durch den Basis- und KTR-Consumer nicht befüllt.
	vr:VerificationReport	Dieses Element wird durch den Basis- und KTR-Consumer nicht befüllt.

	dss:SignatureObject	Enthält im Erfolgsfall die erzeugte Signatur in Form eines dss:SignatureObject-Elements gemäß [OASIS-DSS] (Abschnitt 3.2). Der Signaturwert wird im XML-Element dss:SignatureObject/dss:Base64Signature übergeben. Der Signatur-Typ (CMS Signatur) in dss:SignatureObject/dss:Base64Signature/@Type Die XML-Elemente dss:SignatureObject/ds:Signature dss:SignatureObject/dss:Timestamp dss:SignatureObject/dss:SignaturePtr dss:SignatureObject/dss:Other werden nicht verwendet.
Vorbedingungen	Keine	
Nachbedingungen	Keine	

Das Signieren erfolgt durch Aufruf von PL_TUC_SIGN_DOCUMENT_nonQES {
IDENTIFIKATOR = PrivateKeyOnCard;
DOKUMENT = SIG:Document;
DOKUMENTTYPE = dss:SignatureType;
}

Die folgende Tabelle führt die zulässigen Zertifikate und Schlüssel für die nonQES auf:

Tabelle 30: Tab_Zertifikate_für_Sign/VerifyDocument(nonQES)

Karte	Crypt (Wert)	KeyReference (Verify)	KeyReference (Sign)
		in DF.ESIGN	in DF.ESIGN
SM-B (KTR/Org) (HSM)	RSA	EF.C.HCI.OSIG.R2048	PrK.HCI.OSIG.R2048
	ECC	EF.C.HCI.OSIG.E256	PrK.HCI.OSIG.E256
	RSA_ECC	EF.C.HCI.OSIG.R2048 EF.C.HCI.OSIG.E256	PrK.HCI.OSIG.R2048 PrK.HCI.OSIG.E256

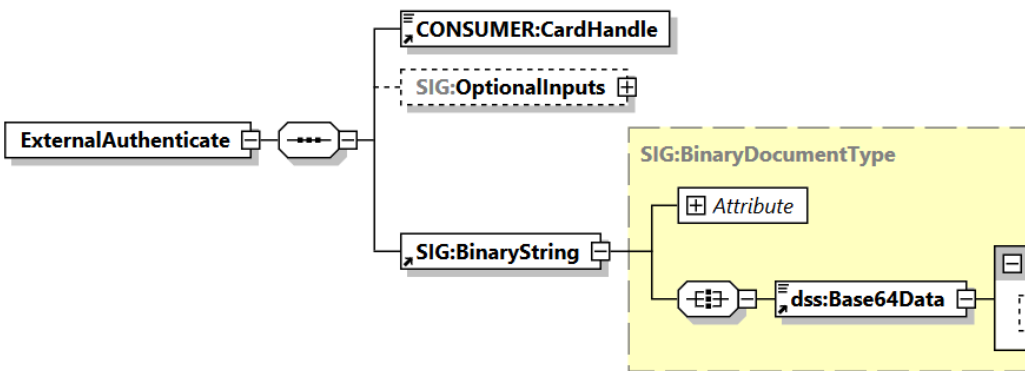
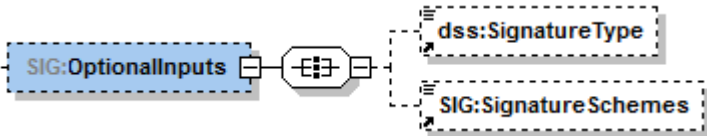
[<=]

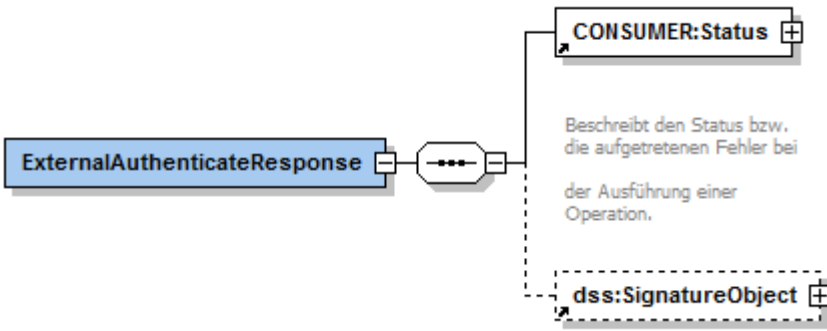
A_17578-03 -Basis- und KTR-Consumer, Operation ExternalAuthenticate

Der Signaturdienst des Basis- und KTR-Consumer MUSS an der Client-Systemschnittstelle die Operation ExternalAuthenticate wie in Tabelle Tab_Operation_ExternalAuthenticate beschrieben anbieten.

Tabelle 31: Tab_Operation_ExternalAuthenticate

Name	ExternalAuthenticate
-------------	----------------------

Beschreibung	Diese Operation versieht einen Binärstring der maximalen Länge 512 Bit mit einer nicht-qualifizierten elektronischen Signatur (nonQES). Dazu wird das Signaturverfahren PKCS#1 oder ECDSA verwendet.	
Aufrufparameter		
	Name	Beschreibung
	CONSUMER:CardHandle	Identifiziert die zu verwendende Signaturquelle. Die Operation unterstützt nur Identitäten gem. Hinweis unter Tabelle 7 Tab_Personalisierung_HSM.
	SIG:OptionalInputs	Enthält optionale Eingangsparameter: 
	SIG:BinaryString	Dieses Element enthält im Kindelement dss:Base64Data den zu signierenden Binärstring. Das XML Attribut SIG:BinaryString/dss:Base64Data/@MimeType muss den Wert "application/octet-stream" haben. Die maximale Länge des Binärstrings beträgt 512 Bit entsprechend der maximal zu erwartenden Hash-Größe. Aus der Länge des Binärstrings wird auf das verwendete Hashverfahren geschlossen. Es werden folgende Längen unterstützt: • 256 Bit: SHA-256 (OID 2.16.840.1.101.3.4.2.1) • 384 Bit: SHA-384 (OID 2.16.840.1.101.3.4.2.2) • 512 Bit: SHA-512 (OID 2.16.840.1.101.3.4.2.3) Im Falle des Signaturverfahrens RSASSA-PKCS1-v1_5 werden SHA-256, SHA-384 und SHA-512 unterstützt. Im Falle des Signaturverfahrens RSASSA-PSS wird SHA-256 unterstützt. Im Falle des Signaturverfahrens ECDSA wird SHA-256 unterstützt. Für die Signaturerstellung gilt: • Im Falle des Signaturverfahrens RSASSA-PKCS1-v1_5

		wird die Ausführung der Methode EMSA-PKCS1-v1_5-ENCODE nach [RFC3447], Abschnitt 9.2, mit Schritt 2, Erstellung des DigestInfo-Datenfeldes begonnen. - Im Falle des Signaturverfahrens RSASSA-PSS wird die Ausführung der Methode EMSA-PSS-ENCODE nach [RFC3447], Abschnitt 9.1.1, mit Schritt 3 begonnen. - Im Falle des Signaturverfahrens ECDSA erfolgt die Signaturerstellung gemäß [BSI-TR-03111]#4.2.1. Als Eingangsparameter wird der Hash vom Aufrufer in SIG: BinaryString übergeben.
	dss: Signature Type	Durch dieses in [OASIS-DSS] (Abschnitt 3.5.1) beschriebene Element wird der Typ der zu erzeugenden Signatur bestimmt. Als Signaturtyp wird unterstützt : PKCS#1-Signatur Durch Übergabe der URI urn:ietf:rfc:3447 wird eine PKCS#1 (Version 2.1) Signatur gemäß [RFC3447] erzeugt, die als <code>dss:Base64Signature</code> mit der oben genannten URI zurückgeliefert wird. ECDSA-Signatur Durch Übergabe der URI urn:bsi:tr:03111:ecdsa wird eine ECDSA Signatur gemäß [BSI-TR-03111]#4.2.1 erzeugt, die als <code>dss:Base64Signature</code> mit der oben genannten URI zurückgeliefert wird. AndereSignatureType-Angaben führen zu Fehlermeldung 4111 (Ungültiger Signaturtyp oder Signaturvariante). Fehlt dieses Element, so wird ebenfalls der Signaturtyp ECDSA-Signatur verwendet.
	SIG: Signature Schemes	Durch dieses Element wird für PKCS#1-Signaturen zwischen den folgenden SignatureScheme-Optionen unterschieden: - RSASSA-PSS - RSASSA-PKCS1-v1_5 Fehlt dieses Element, so wird als Default-SignatureScheme RSASSA-PSS gewählt.
Rückgabe		

	CONSUMER: Status	Enthält den Status der ausgeführten Operation.
	dss: Signature Object	Enthält im Erfolgsfall die erzeugte Signatur in Form eines dss:SignatureObject-Elements gemäß [OASIS-DSS] (Abschnitt 3.2). Der Signaturwert wird im XML-Element dss:SignatureObject/dss:Base64Signature übergeben. Das XML-Attribut dss:SignatureObject/dss:Base64Signature/@Type kennzeichnet durch den Wert: • urn:ietf:rfc:3447 den Signatur-Typ PKCS#1 bzw. • urn:bsi:tr:03111:ecdsa den Signatur-Typ ECDSA. Die XML-Elemente dss:SignatureObject/ds:Signature dss:SignatureObject/dss:Timestamp dss:SignatureObject/dss:SignaturePtr dss:SignatureObject/dss:Other werden nicht verwendet.
Vorbedingungen	Keine	
Nachbedingungen	Keine	

Der Ablauf der Operation ExternalAuthenticate ist in Tabelle Tab_Ablauf_ExternalAuthenticate beschrieben:

Tabelle 32: Tab_Ablauf_ExternalAuthenticate

Nr.	Aufruf Technischer Use Case oder Interne Operation	Beschreibung
1.	checkArguments	Alle übergebenen Parameterwerte werden auf Konsistenz und Gültigkeit überprüft. Treten hierbei Fehler auf, so bricht die Operation mit Fehler 4000 ab.
2.	Signiere	Das Signieren erfolgt durch Aufruf von <pre>PL_TUC_SIGN_HASH_nonQES { IDENTIFIKATOR = CardHandle; SIGNATURVERFAHREN = SIG:SignatureSchemes; HASHWERT = SIG:BinaryString; }</pre>

Tabelle 33: Tab_Fehler_ExternalAuthenticate

Fehlercode	ErrorType	Severity	Fehlertext
Neben den Fehlercodes der aufgerufenen TUCs können folgende weitere Fehlercodes auftreten:			
4000	Technical	Error	Syntaxfehler
4111	Technical	Error	Ungültiger Signaturtyp oder Signaturvariante

Der zulässige private Schlüssel für die Nutzung durch die Operation ExternalAuthenticate ist für SM-B PrK.HCI.AUT in DF.ESIGN.【<=】

6.5.2 Senden von Nachrichten

A_17300 -Initialer SMTP-Dialog

Das KOM-LE-Clientmodul MUSS, nachdem die SMTP-Verbindung zwischen dem Clientsystem und dem Clientmodul aufgebaut wird und bis zum Punkt an dem das Clientsystem die Bestätigung des Erfolgs oder Misserfolgs seiner Authentifizierung erwartet, einen SMTP-Dialog entsprechend der Tabelle Tab_SMTP_Ant_Init mit dem Clientsystem führen.

Tabelle 34: Tab_SMTP_Ant_Init Antworten Clientmodul im CONNECT-Zustand

SMTP-Kommando (Clientsystem -> Clientmodul)	SMTP-Antwortcode (Clientmodul -> Clientsystem)
HELO	„250 OK“ Antwortcode
EHLO	„250 OK“ Antwortcode mit folgenden EHLO-Kennworten: SIZE <size> AUTH LOGIN PLAIN 8BITMIME ENHANCEDSTATUSCODES DSN und <size> gleich oder größer als 35882577
AUTH	Anmeldungsdaten erhalten und Verbindungsaufbau mit dem MTA beginnen
RSET, NOOP	„250 OK“ Antwortcode
MAIL, RCPT, DATA	„530 5.7.0“ Antwortcode (Authentication required)
QUIT	„221 OK“ Antwortcode senden und die Verbindung mit dem Clientsystem schließen
Andere Meldungen	„502 5.5.1“ Antwortcode (Invalid command)

【<=】

A_17302 -Authentisierung gegenüber dem SMTP-Server mit Benutzernamen und Passwort

Das KOM-LE-Clientmodul MUSS den Benutzernamen und das Passwort, die es vom Clientsystem erhalten hat, für die Authentisierung gegenüber dem SMTP-Server verwenden. [≤]

A_17303 -Ergebnis des Verbindungsaufbaus mit dem SMTP-Server

Das KOM-LE-Clientmodul MUSS das Clientsystem über das Ergebnis des Verbindungsaufbaus mit dem MTA mit den in Tabelle Tab_SMTP_Verbindung beschriebenen SMTP-Antwortcodes informieren.

Tabelle 35: Tab_SMTP_Verbindung SMTP-Antwortcodes für MTA-Verbindungsaufbau

Bedingung	SMTP-Antwortcode (Clientmodul -> Clientsystem)
Das Clientmodul hat sich erfolgreich gegenüber dem MTA mit den vom Clientsystem erhaltenen Anmeldungsdaten authentifiziert.	235 2.7.0 (Authentication successful)
Das Clientsystem verwendet für die SMTP-Authentifizierung einen anderen Mechanismus als PLAIN oder LOGIN.	504 5.7.4 (Security features not supported)
Die Verbindung zwischen dem Clientmodul und dem MTA kann nicht aufgebaut werden.	454 4.7.0 (Temporary authentication failure)
Die Authentifizierung gegenüber dem MTA schlägt fehl.	535 5.7.8 (Authentication credentials invalid)

[≤]

A_17305 -Verwenden von PL_TUC_SIGN_DOCUMENT_nonQES und PL_TUC_HYBRID_ENCIPHER

Das KOM-LE-Clientmodul MUSS für das Signieren und Verschlüsseln der Nachrichten entsprechend dem KOM-LE-S/MIME-Profil die Systemprozesse PL_TUC_SIGN_DOCUMENT_nonQES und PL_TUC_HYBRID_ENCIPHER des Basis-Consumers verwenden. [≤]

A_17306 -Vorgehen bei Signatur und Verschlüsselung einer KOM-LE Nachricht

Das KOM-LE-Clientmodul MUSS zur Signatur und Verschlüsselung von KOM-LE Nachrichten das folgende Vorgehen umsetzen:

1. Unter Verwendung des Systemprozesses PL_TUC_SIGN_DOCUMENT_nonQES des Basis-Consumers erzeugt das Clientmodul KOM-LE einen binären Opak-signierten CMS-Container entsprechend dem KOM-LE-S/MIME-Profil.
2. Der binäre CMS-Container mit der signierten Nachricht wird als „application/pkcs7-mime“ MIME-Einheit vom smime-type „signed-data“ mit dem Content-Transfer-Encoding „binary“ verpackt.
3. Zur CMS-Verschlüsselung übergibt das KOM-LE-Clientmodul beim Aufruf des Systemprozesses PL_TUC_HYBRID_ENCIPHER die in Schritt zwei erzeugte Nachricht als binär-Dokument. Als Antwort erhält das KOM-LE-Clientmodul einen binären CMS-Container zurück.
4. Der aus der Verschlüsselung resultierende CMS-Container wird in eine „application/pkcs7-mime“ MIME-Einheit vom smime-type „authenticated-enveloped-data“ mit dem Content-Transfer-Encoding „base64“ verpackt.

[<=]

6.5.3 Empfangen von Nachrichten

A_17328 -POP3-Dialog zur Authentifizierung

Das KOM-LE-Clientmodul MUSS, nachdem die POP3-Verbindung zwischen dem Clientsystem und dem Clientmodul aufgebaut wurde und bis zu dem Punkt an dem das Clientsystem die Bestätigung des Erfolgs oder Misserfolgs seiner Authentifizierung erwartet, einen POP3-Dialog entsprechend Tabelle Tab_POP3_Ant_Init mit dem Clientsystem führen.

Tabelle 36: Tab_POP3_Ant_Init Antworten Clientmodul im CONNECT-Zustand

Clientsystem -> Clientmodul	Clientmodul -> Clientsystem
CAPA	„+OK“ Antwortcode mit folgenden CAPA Kennworten: TOP USER SASL PLAIN UIDL
USER, AUTH	Anmeldungsdaten erhalten und Verbindungsaufbau mit dem POP3-Server fortsetzen
QUIT	„+ OK“ Antwortcode senden und die Verbindung mit dem Clientsystem schließen
Andere Meldungen	„-ERR“ Antwortcode

[<=]

A_17330 -Authentifizierung gegenüber POP3-Server mit Benutzernamen und Passwort

Das KOM-LE-Clientmodul MUSS den Benutzernamen und das Passwort, die es vom Clientsystem erhalten hat, für die Authentifizierung gegenüber dem POP3-Server verwenden.[<=]

A_17331 -Ergebnis des Verbindungsaufbaus mit dem POP3-Server

Das KOM-LE-Clientmodul MUSS das Clientsystem über das Ergebnis des Verbindungsaufbaus mit dem POP3-Server mit den in der Tabelle Tab_POP3_Verbindung beschriebenen POP3-Antwortcodes informieren.

Tabelle 37: Tab_POP3_Verbindung Antwortcodes für POP3-Server-Verbindungsaufbau

Bedingung	POP3 Antwortcode (Clientmodul -> Clientsystem)
Das Clientsystem hat sich erfolgreich gegenüber dem POP3-Server mit den vom Clientsystem erhaltenen Anmeldungsdaten authentifiziert.	+OK
Das Clientsystem verwendet für die POP3-Authentifizierung einen anderen Mechanismus als USER/PASS oder PLAIN.	-ERR
Die Verbindung zwischen dem Clientmodul und dem POP3-Server kann nicht aufgebaut werden.	-ERR

Die Authentifizierung gegenüber dem MTA schlägt fehl.	-ERR
---	------

[<=]

A_17333 -E-Mail-Adresse des den Abholvorgang auslösenden Nutzers

Das KOM-LE-Clientmodul MUSS den vom Clientsystem erhaltenen POP3-Usernamen als die E-Mail-Adresse des den Abholvorgang auslösenden Nutzers betrachten.[<=]

A_17504 -Verwenden von PL_TUC_VERIFY_DOCUMENT_nonQES und PL_TUC_HYBRID_DECIPHER

Das KOM-LE-Clientmodul MUSS für das Entschlüsseln und die Signaturprüfung der Nachrichten die Systemprozesse PL_TUC_VERIFY_DOCUMENT_nonQES und PL_TUC_HYBRID_DECIPHER des Basis-Consumers verwenden.

[<=]

A_17337 -Abbrechen des Entschlüsseln, wenn die erforderliche SM-B nicht verfügbar ist

Das KOM-LE-Clientmodul MUSS die Entschlüsselung einer Nachricht abbrechen, wenn die für die Entschlüsselung erforderliche SM-B nicht verfügbar ist.[<=]

A_17338 -Abbrechen des Entschlüsseln, wenn Freischaltung der erforderlichen SM-B fehlschlägt

Das KOM-LE-Clientmodul MUSS die Entschlüsselung einer Nachricht abbrechen, wenn die Freischaltung der für die Entschlüsselung erforderlichen SM-B fehlschlägt.[<=]

6.6 Realisierung der Leistungen der TI-Plattform

A_18130 -Nutzung von PL_TUC_CARD Systemprozessen

Der Basis-Consumer MUSS für den Zugriff auf Smartcards die in TAB_Systemprozesse mit PL_TUC_CARD_* bezeichneten Systemprozesse benutzen.

[<=]

6.6.1 Schnittstelle für Kartenkommandos

Wenn der Basis-Consumer Smartcards unterstützt, muss er eine Schnittstelle zu Karten der TI über ein Kartenterminal herstellen. Diese Schnittstelle muss die von den Plattformprozessen erzeugten, kartenverständlichen APDUs an die Karte übertragen. Neben proprietären Schnittstellentreibern von Kartenterminalherstellern existiert eine Reihe standardisierter Schnittstellen, die auch von verschiedenen Betriebssystemen zur Anbindung handelsüblicher Kartenterminals unterstützt werden.

Die folgenden Anforderungen betreffen die gemäß [gemSpec_Systemprozesse_dezTI#ENV_TUC_CARD_APDU_TRANSPORT] zu beschreibende Schnittstelle.

A_18166 -Vertrauliche und integritätsgeschützte Kommunikation mit KT

Wenn der Basis-Consumer Smartcards unterstützt, MUSS der Basis-Consumer mit dem Kartenterminal ausschließlich über eine vertrauliche, integritätsgeschützte Verbindung kommunizieren.[<=]

A_18097-01 -Schnittstelle für Kartenkommandos

Wenn der Basis-Consumer Smartcards unterstützt, MUSS er eine sichere Schnittstelle für die Übertragung von Smartcard-APDUs gemäß [CT-API] implementieren.

[<=]

A_18100-01 -Ergänzende Standards für Kartenkommandos

Der Basis-Consumer KANN eine Schnittstelle für die Übertragung von SmartCard-APDUs auf Basis des SICCT-Protokolls gemäß [CCID] und unter Verwendung der vom Hersteller des Kartenterminals ggf. bereitgestellten Hardwaretreiber implementieren.

[<=]

A_18163 -Kartenterminal für Basis-Consumer

Wenn der Basis-Consumer Smartcards unterstützt, MUSS er mindestens ein Kartenterminal enthalten.

[<=]

A_18102 -PIN-Eingabe nicht speichern

Der Basis-Consumer DARF ein eingegebenes PIN-Geheimnis NICHT speichern.[<=]

A_18103 -PIN-Geheimnis ausschließlich an Karte übermitteln

Der Basis-Consumer MUSS sicherstellen, dass das eingegebene PIN-Geheimnis ausschließlich an die Karte und nicht an andere Adressaten übermittelt wird.

[<=]

6.6.2 Schnittstelle für PIN-Operationen und Anbindung der Karten der TI

Anwendungsfälle zur PIN-Verwaltung, zur Kartenfreischaltung oder weiterer Fachanwendungen können die Eingabe eines PIN- oder PUK-Geheimnisses erfordern. Der Zugriff auf Karten der TI erfolgt über die Systemprozesse PL_TUC_CARD_*. Der Basis-Consumer als Realisierungsumgebung der Systemprozesse muss seinerseits die von der Plattform geforderten Schnittstellen gemäß [gemSpec_Systemprozesse_dezTI#ENV_TUC_CARD_SECRET_INPUT] implementieren, um die Kommunikation der Plattform mit dem Benutzer zu ermöglichen.

Die Schnittstelle für den Transport von Kartenkommandos ist in Kapitel 6.6.1 beschrieben und umfasst das Kartenterminal, Eingabemedium und Hinweistexte an den Benutzer. Diese kann je nach Konfiguration an einem Gerät als Kartenterminal oder auch eine Kombination aus Bildschirmausgabe, Kartenterminal-PIN-Pad und/oder Tastatureingabe erfolgen.

A_18107-01 -Schnittstelle zur Eingabe des PIN/PUK-Geheimnisses

Wenn der Basis-Consumer Smartcards unterstützt, MUSS er eine Operation gemäß [gemSpec_Systemprozesse_dezTI#ENV_TUC_CARD_SECRET_INPUT] zur Eingabe eines PIN/PUK-Geheimnisses und Weiterleitung an eine Smartcard mit folgenden Parametern implementieren:

Eingabeparameter:

- Identifikator
- Aktion
- minLength
- maxLength
- commandApduPart

Rückgabewerte

- responseApdu

[<=]

A_18108-01 -Umsetzung ENV_TUC_CARD_SECRET_INPUT

Wenn der Basis-Consumer Smartcards unterstützt, MUSS er die Abbildung der Eingabeparameter auf die Rückgabewerte der Operation ENV_TUC_SECRET_INPUT derart

umsetzen, dass

- die Eingabeparameter Identifikator und Aktion für einen Hinweistext an den Benutzer verwendet werden, welche Aktion auf welchem konkreten Kartenobjekt (z.B. Name einer PIN) durchgeführt wird,
- der commandApduPart um das Benutzergeheimnis ergänzt wird,
- der commandApduPart über die Schnittstelle für Kartenkommandos an die Karte gesendet wird

und die Antwortnachricht der Karte als responseApdu an den Aufrufer zur Auswertung zurückgegeben wird.

[<=]

A_18109 -Minimalprinzip Karteninteraktion

Der Basis-Consumer DARF ein Kartenkommando NICHT an eine angebundene Karte weiterleiten, wenn dies nicht explizit im Kontext eines Anwendungsfalls (intendierte Kartenoperationen und Erhöhen des Sicherheitszustands der Karte, falls erforderlich) erforderlich ist.[<=]

7 Anhang A - Verzeichnisse

7.1 Abkürzungen

Kürzel	Erläuterung
AZPD	Anbieter Zentrale Plattform Dienste
CMS	Cryptographic Message Syntax
HSM	Hardware Security Module
IPv4	Internet Protokoll Version 4
IPv6	Internet Protokoll Version 6
KOM-LE	Kommunikation für Leistungserbringer
LDAP	Leightweight Directory Access Protocol
MIME	Multipurpose Internet Mail Extensions
MTA	Mail Transfer Agent
POP3	Post Office Protocol Version 3
S/MIME	Secure/Multipurpose Internet Mail Extensions
SM-B	Security Module Typ B
SMTP	Simple Mail Transfer Protocol
TI	Telematikinfrastuktur
WANDA Basic	Weitere Anwendungen für den Datenaustausch ohne Nutzung der TI oder derer kryptografischen Identitäten
WANDA Smart	Weitere Anwendungen für den Datenaustausch mit Nutzung der TI oder derer kryptografischen Identitäten für eigene Anwendungszwecke

7.2 Glossar

Begriff	Erläuterung
Funktionsmerkmal	Der Begriff beschreibt eine Funktion oder auch einzelne, eine logische Einheit bildende Teilfunktionen der TI im Rahmen der funktionalen Zerlegung des Systems.

Das Glossar wird als eigenständiges Dokument, vgl. [gemGlossar] zur Verfügung gestellt.

7.3 Abbildungsverzeichnis

Abbildung 1: Systemkontext für Basis-Consumer.....	9
--	---

7.4 Tabellenverzeichnis

Tabelle 1: Mapping der Netzwerksegmente.....	13
Tabelle 2: TAB_CONS_687 DNS-Forwards des DNS-Servers.....	16
Tabelle 3: TAB_CONS_648 – TUC_CONS_362 „Liste der Dienste abrufen“	16
Tabelle 4: Basisanwendung Namensdienst.....	17
Tabelle 5: Konfigurationsparameter Namensdienst.....	18
Tabelle 6: Einsehbare Konfigurationsparameter Namensdienst.....	18
Tabelle 7: Tab_Personalisierung_HSM – Personalisierung des HSM.....	19
Der Anbieter des Basis-Consumer MUSS sicherstellen, dass dem clientseitigen Nutzer jederzeit die Möglichkeit zur Verfügung gestellt wird zu wählen, mit welcher der ihm zugeordneten Identitäten die Consumer Operationen aufgerufen werden. Dabei MÜSSEN dem Nutzer eindeutig für jede Identität die in TAB_CardHandle_Map enthaltenen Informationen zugeordnet werden. Ungültige oder vom Identitätsträger (HSM) entfernte Identitäten DÜRFEN dem Nutzer dabei NICHT zur Verfügung gestellt werden. <i>Tabelle 8: TAB_CardHandle_Map</i>	20
Tabelle 9: Tab_Verschlüsselungsdienst.....	22
Tabelle 10: Tab_Operation_EncryptDocument.....	23
Tabelle 11: Tab_Operation_DecryptDocument.....	26
Tabelle 12: Tab_Signaturdienst.....	28
Tabelle 13: Tab_Operation_SignDocument.....	28
Tabelle 14: Tab_Operation_SignPlain.....	32
Tabelle 15: Tab_Operation_VerifyDocument.....	34
Tabelle 16: Tab_Operation_ExternalAuthenticate.....	38
Tabelle 17: Tab_Ablauf_ExternalAuthenticate.....	40
Tabelle 18: Tab_Fehler_ExternalAuthenticate.....	40
Tabelle 19: Tab_Zertifikatsdienst.....	41

Tabelle 20: Tab_Operation_ReadCertificate.....	42
Tabelle 21: Tab_Ablauf_ReadCertificate.....	44
Tabelle 22: Tab_Fehler_ReadCertificate.....	45
Tabelle 23: Tab_IdentityObjekte_ReadCertificateKartenobjekt in Abhängigkeit vom kryptographischen Verfahren.....	46
Tabelle 24: Tab_Operation_VerifyCertificate.....	46
Tabelle 25: Tab_Ablauf_VerifyCertificate.....	48
Tabelle 26: Tab_Übersicht_VerificationResult_VerifyCertificate.....	48
Tabelle 27: Tab_Ldap_TUC_Mapping.....	49
Tabelle 28: Tab_ECC-preferred-Funktionalität.....	50
Tabelle 29: Tab_Operation_SignDocument.....	53
Tabelle 30: Tab_Zertifikate_für_Sign/VerifyDocument(nonQeS).....	57
Tabelle 31: Tab_Operation_ExternalAuthenticate.....	58
Tabelle 32: Tab_Ablauf_ExternalAuthenticate.....	61
Tabelle 33: Tab_Fehler_ExternalAuthenticate.....	61
Tabelle 34: Tab_SMTP_Ant_Init Antworten Clientmodul im CONNECT-Zustand.....	62
Tabelle 35: Tab_SMTP_Verbindung SMTP-Antwortcodes für MTA-Verbindungsaufbau.....	63
Tabelle 36: Tab_POP3_Ant_Init Antworten Clientmodul im CONNECT-Zustand.....	64
Tabelle 37: Tab_POP3_Verbindung Antwortcodes für POP3-Server-Verbindungsaufbau...	64
Tabelle 38: Tab_Schema_Versionen Versionen der Schemas aus dem Namensraum des Basis-Consumers.....	73
Tabelle 39: TAB_Systemprozesse - Verwendete Plattformleistungen.....	74

7.5 Referenzierte Dokumente

7.5.1 Dokumente der gematik

Die nachfolgende Tabelle enthält die Bezeichnung der in dem vorliegenden Dokument referenzierten Dokumente der gematik zur Telematikinfrastruktur.

[Quelle]	Herausgeber: Titel
[gemGlossar]	gematik: Einführung der Gesundheitskarte - Glossar
[gemSMIME_KOMLE]	gematik: S/MIME-Profil Kommunikation Leistungserbringer(KOM-LE)
[gemSpec_CM_KOMLE]	gematik: Spezifikation KOM-LE-Clientmodul
[gemSpec_Systemprozesse_dezTI]	gematik: Spezifikation der Systemprozesse der dezentralen TI

[gemSpec_VZD]	gematik: Spezifikation Verzeichnisdienst
[gemKPT_Arch_TIP]	gematik: Konzept Architektur der TI-Plattform
[gemSpec_PKI]	gematik: Übergreifende Spezifikation PKI
[gemSpec_Net]	gematik: Übergreifende Spezifikation Netzwerk

7.5.2 Weitere Dokumente

[Quelle]	Herausgeber (Erscheinungsdatum): Titel
[BSI-TR-03111]	BSI TR-31111: Elliptic Curve Cryptography, Version 2.10, Juni 2018
[RFC1939]	RFC 1939: Post Office Protocol – Version 3, J. Myers, M. Rose, Mai 1996
[RFC2045]	RFC 2045: Multipurpose Internet Mail Extension (MIME) Part One: Format of Internet Message Bodies, N. Freed, N. Borenstein, November 1996
[RFC2119]	RFC 2119 (März 1997): Key words for use in RFCs to Indicate Requirement Levels S. Bradner
[RFC4511]	RFC 4511: Lightweight Directory Access Protocol (LDAP), J. Sermersheim, Juni 2006
[RFC4954]	RFC 4954: SMTP Service Extension for Authentication, R. Siemborski, A. Melnikov, März 2007
[RFC5083]	RFC 5083: Authenticated-Enveloped-Data Content Type, R. Housley, November 2007
[RFC5321]	RFC 5321: Simple Mail Transfer Protocol, J. Klensin, Oktober 2008
[RFC5652]	RFC 5652: Cryptographic Message Syntax (CMS), R. Housley, September 2009
[RFC5751]	RFC 5751: Secure/Multipurpose Internet Mail Extensions (S/MIME) Version 3.2 Message Specification, B. Ramsdell, S. Turner, Januar 2010
[RFC1812]	RFC 1812: Requirements for IP Version 4 Routers, Juni 1995
[RFC2644]	RFC 2644: Changing the Default for Directed Broadcasts in Routers, August 1999
[RFC791]	RFC 791: Internet Protocol, September 1981
[RFC3022]	RFC 3022: Traditional IP Network Address Translator (Traditional NAT), Januar 2001
[RFC1918]	RFC 1918: Address Allocation for Private Internets, Februar 1996
[RFC6598]	RFC 6598: IANA-Reserved IPv4 Prefix for Shared Address Space, April

	2012
[OASIS-DSS]	OASIS: Digital Signature Service Core Protocols, Elements, and Bindings, Version 1.0, OASIS Standard, via http://docs.oasis-open.org/dss/v1.0/oasis-dss-core-spec-v1.0-os.pdf
[OASIS-SP]	OASIS: Signature Policy Profile of the OASIS Digital Signature Services Version 1.0, Committee Draft 01, 18 May 2009, http://docs.oasis-open.org/dss-x/profiles/sigpolicy/oasis-dssx-1.0-profiles-sigpolicy-cd01.pdf
[OASIS-VR]	OASIS: Profile for comprehensive multi-signature verification reports for OASIS Digital Signature Services Version 1.0, Committee Specification 01, 12 November 2010, http://docs.oasis-open.org/dss-x/profiles/verificationreport/oasis-dssx-1.0-profiles-vr-cs01.pdf
[XMLEnc]	XML Encryption Syntax and Processing W3C Recommendation 11 April 2013 http://www.w3.org/TR/xmlenc-core1/
[XPath]	W3C Recommendation (14 December 2010) XML Path Language (XPath) 2.0 (Second Edition) http://www.w3.org/TR/2010/REC-xpath20-20101214/
[CMS]	Cryptographic Message Syntax (CMS), September 2009 http://tools.ietf.org/html/rfc5652
[Canon XML1.1]	Canonical XML Version 1.1 http://www.w3.org/TR/2008/REC-xml-c14n11-20080502/
[CAeS]	ETSI: Electronic Signature Formats, Electronic Signatures and Infrastructures (ESI) – Technical Specification, ETSI TS 101 733 V2.2.1, 2008-07, via http://www.etsi.org
[CT-API]	https://www.tuvit.de/de/aktuelles/beitraege-white-paper/card-terminal-application-programing-interface-fuer-chipkartenanwendungen//
[CCID]	https://usb.org.10-1-108-210.causewaynow.com/sites/default/files/DWG_Smart-Card_CCID_Rev110.pdf

8 Anhang B - Übersicht über die verwendeten Versionen

Für den Fall, dass Schnittstellenversionen unterstützt werden müssen, die den gleichen TargetNamespace nutzen, kann der Basis-Consumer zu diesen Schnittstellenversionen einheitlich einen SOAP-Endpunkt anbieten, der die höchste der Schnittstellenversionen implementiert.

Tabelle 38: Tab_Schema_Versionen Versionen der Schemas aus dem Namensraum des Basis-Consumers

Schemas aus dem Namensraum des Basis-Consumer „http://ws.gematik.de/consumer“		
Name	Version	TargetNamespace
CertificateService.wsdl	3.0.0	http://ws.gematik.de/consumer/CertificateService/WSDL/v3.0
CertificateService.xsd	3.0.0	http://ws.gematik.de/consumer/CertificateService/v3.0
CertificateServiceCommon.xsd	2.0.0	http://ws.gematik.de/consumer/CertificateServiceCommon/v2.0
ConsumerCommon.xsd	2.0.0	http://ws.gematik.de/consumer/ConsumerCommon/v2.0
EncryptionService.wsdl	3.0.1	http://ws.gematik.de/consumer/EncryptionService/WSDL/v3.0
EncryptionService.xsd	3.0.1	http://ws.gematik.de/consumer/EncryptionService/v3.0
SignatureService.wsdl	3.1.0	http://ws.gematik.de/consumer/SignatureService/WSDL/v3.1
SignatureService.xsd	3.1.0	http://ws.gematik.de/consumer/SignatureService/v3.1

9 Anhang C - Übersicht der genutzten Systemprozesse

Der Basis-Consumer verwendet u.a. die in Tabelle TAB_Systemprozesse dargestellten Plattformleistungen aus [gemSpec_Systemprozesse_dezTI].

Tabelle 39: TAB_Systemprozesse - Verwendete Plattformleistungen

Kürzel	Bezeichnung
PL_TUC_HYBRID_DECIPHER	Hybrid entschlüsseln
PL_TUC_HYBRID_ENCIPHER	Hybrid verschlüsseln
PL_TUC_SIGN_DOCUMENT_nonQES	Dokument nonQES signieren
PL_TUC_SIGN_HASH_nonQES	mit Karten-Identität signieren
PL_TUC_VERIFY_DOCUMENT_nonQES	nonQES Dokumentensignatur verifizieren
PL_TUC_PKI_VERIFY_CERTIFICATE	Prüfung eines Zertifikats der TI
PL_TUC_VZD_BIND	Verbindung aufbauen
PL_TUC_VZD_UNBIND	Verbindung trennen
PL_TUC_VZD_SEARCH	Verzeichnis abfragen
PL_TUC_VZD_ABANDON	Verzeichnisabfrage abbrechen
PL_TUC_NET_SYNC_TIME	Zeit synchronisieren
PL_TUC_CARD_INFORMATION	gesammelte Statusinformationen zu einer Karte
PL_TUC_CARD_RESET	Rücksetzen einer Karte
PL_TUC_CARD_CHANGE_PIN	PIN ändern
PL_TUC_CARD_ENABLE_PIN	PIN-Schutz einschalten
PL_TUC_CARD_DISABLE_PIN	PIN-Schutz abschalten
PL_TUC_CARD_VERIFY_PIN	Benutzer verifizieren
PL_TUC_CARD_ACTIVATE_APPLICATION	Anwendung aktivieren

PL_TUC_CARD_DEACTIVATE_APPLICATION	Anwendung deaktivieren
PL_TUC_CARD_GET_CHALLENGE	Auslesen einer Zufallszahl